

**UNIVERSIDADE DE MOGI DAS CRUZES**

**DANIEL PEREIRA BIONDI**

**LORENA CUNHA DE SOUZA**

**RODRIGO DINIZ DA SILVA RIBEIRO**

**ECO A:** plataforma web integrada para planejamento terapêutico e acompanhamento fonoaudiológico infantil em conformidade com a LGPD.

Mogi das Cruzes, SP

2026

**UNIVERSIDADE DE MOGI DAS CRUZES**

**DANIEL PEREIRA BIONDI**

**LORENA CUNHA DE SOUZA**

**RODRIGO DINIZ DA SILVA RIBEIRO**

**ECOIA:** plataforma web integrada para planejamento terapêutico e acompanhamento fonoaudiológico infantil em conformidade com a LGPD.

Trabalho do curso de Sistemas de Informação da Universidade de Mogi das Cruzes como parte dos requisitos para conclusão da disciplina de Políticas de Segurança da Informação.

Mogi das Cruzes, SP

2026

# SUMÁRIO

## Sumário

|                                                                       |           |
|-----------------------------------------------------------------------|-----------|
| <b>Visão Geral do Sistema .....</b>                                   | <b>6</b>  |
| <b>Especificação do Sistema (SRS / ERS) .....</b>                     | <b>7</b>  |
| <b>1.1 Declaração e Delimitação de Escopo (Scope Statement) .....</b> | <b>7</b>  |
| <b>Escopo Positivo (In-Scope): .....</b>                              | <b>8</b>  |
| <b>Escopo Negativo (Out-of-Scope): .....</b>                          | <b>9</b>  |
| <b>1.2 Requisitos Funcionais (RF) .....</b>                           | <b>10</b> |
| <b>1.3 Requisitos Não Funcionais (RNF).....</b>                       | <b>19</b> |
| <b>1.4 Regra de Negócio (RN).....</b>                                 | <b>23</b> |
| <b>1.5 Casos de Uso de Engenharia de Software .....</b>               | <b>25</b> |
| <b>1.5 Diagrama de Arquitetura .....</b>                              | <b>27</b> |
| <b>2. Fluxos de autenticação e dados documentados.....</b>            | <b>28</b> |
| <b>2.1 Principais arquivos relacionado à autenticação .....</b>       | <b>28</b> |
| <b>2.2 Fluxo de autenticação.....</b>                                 | <b>29</b> |
| <b>2.3 Login sem 2FA .....</b>                                        | <b>30</b> |
| <b>2.4 Login com 2FA.....</b>                                         | <b>30</b> |
| <b>2.5 Ativação do 2FA.....</b>                                       | <b>30</b> |
| <b>2.6 Logout .....</b>                                               | <b>31</b> |
| <b>3. Proteção e Armazenamento de Senhas .....</b>                    | <b>31</b> |
| <b>3.1 Algoritmo de Hash .....</b>                                    | <b>31</b> |
| <b>3.2 Parâmetros de Custo .....</b>                                  | <b>32</b> |
| <b>3.3 Salt Criptográfico.....</b>                                    | <b>32</b> |
| <b>3.4 Persistência do Hash e Salt .....</b>                          | <b>32</b> |
| <b>4. Autenticação em Dois Fatores .....</b>                          | <b>33</b> |
| <b>4.1 Implementação.....</b>                                         | <b>33</b> |
| <b>5. Gerenciamento de Sessões.....</b>                               | <b>33</b> |
| <b>5.1 Duração da Sessão.....</b>                                     | <b>33</b> |
| <b>5.2 Armazenamento das Sessões.....</b>                             | <b>34</b> |
| <b>5.3 Invalidação no Logout.....</b>                                 | <b>34</b> |
| <b>6. Proteção contra Tentativas Excessivas de Autenticação .....</b> | <b>34</b> |

|                                                                   |    |
|-------------------------------------------------------------------|----|
| 6.1 Login .....                                                   | 34 |
| 6.2 Autenticação em Dois Fatores .....                            | 35 |
| 7. Justificativas Técnicas .....                                  | 35 |
| 7.1 Argon2id .....                                                | 35 |
| 7.2 Parâmetros de Hash .....                                      | 35 |
| 7.3 TOTP .....                                                    | 35 |
| 7.4 Rate Limiting .....                                           | 35 |
| 8. Evidências de Funcionamento .....                              | 36 |
| 9. Matriz de Atendimento aos Requisitos .....                     | 36 |
| 10. Recuperação de Senha .....                                    | 38 |
| 10.1 Visão Geral .....                                            | 38 |
| 11. Fluxo de Recuperação de Senha .....                           | 38 |
| 11.1 Solicitação de Recuperação .....                             | 38 |
| 11.2 Redefinição com Token Válido .....                           | 39 |
| 11.3 Token Inválido, Expirado ou Reutilizado .....                | 40 |
| 12. Token de Recuperação .....                                    | 40 |
| 12.1 Geração e Armazenamento .....                                | 40 |
| 12.2 Tempo de Expiração .....                                     | 40 |
| 12.3 Invalidação após o Uso .....                                 | 41 |
| 12.4 Tratamento de Token Inválido .....                           | 41 |
| 13. Registro e Rastreabilidade .....                              | 41 |
| 13.1 Registro da Solicitação .....                                | 41 |
| 13.2 Registro de Sucesso .....                                    | 42 |
| 13.3 Registro de Falha .....                                      | 42 |
| 14. Justificativas Técnicas .....                                 | 42 |
| 14.1 Utilização do Mecanismo Nativo do Laravel .....              | 42 |
| 14.2 Armazenamento do Hash do Token .....                         | 43 |
| 14.3 Prazo de validade .....                                      | 43 |
| 14.4 Registro das Etapas do Processo .....                        | 43 |
| 15. Evidências de Funcionamento .....                             | 43 |
| 16. Matriz de Atendimento aos Requisitos .....                    | 44 |
| 17. Engenharia de Segurança da Informação & Criptografia .....    | 44 |
| 17.1 Memorial de Cálculo de Benchmarking de Hash (Argon2id) ..... | 44 |

|                                                                        |    |
|------------------------------------------------------------------------|----|
| 17.2 Gestão de Chaves e Criptografia em Repouso .....                  | 45 |
| 17.3 Gestão de Credenciais .....                                       | 47 |
| 17.4 Ciclo de Vida das Credenciais.....                                | 47 |
| 17.5 Armazenamento e Verificação de Senhas .....                       | 48 |
| 17.6 Autenticação em Dois Fatores.....                                 | 48 |
| 17.7 Recuperação e Substituição da Senha .....                         | 49 |
| 17.8 Proteção contra Tentativas de Descoberta de Credenciais .....     | 49 |
| 17.9 Síntese da Gestão de Credenciais .....                            | 49 |
| 18. Criptografia e Comunicação Segura.....                             | 50 |
| 18.1 Visão Geral .....                                                 | 50 |
| 19. Comunicação Segura .....                                           | 50 |
| 19.1 HTTPS/TLS .....                                                   | 50 |
| 19.2 Redirecionamento de HTTP para HTTPS.....                          | 50 |
| 19.3 Reconhecimento de HTTPS atrás do Proxy .....                      | 51 |
| 20. Criptografia de Dados em Repouso .....                             | 51 |
| 20.1 Campos Protegidos.....                                            | 51 |
| 20.2 Funcionamento da Criptografia .....                               | 52 |
| 20.3 Dados Não Criptografados em Nível de Aplicação .....              | 52 |
| 21. Proteção da Chave Criptográfica .....                              | 53 |
| 22. Justificativas Técnicas.....                                       | 53 |
| 22.1 Utilização da Criptografia Nativa do Laravel.....                 | 53 |
| 22.2 AES-256-CBC .....                                                 | 53 |
| 22.3 HTTPS em Toda a Aplicação.....                                    | 54 |
| 22.4 Separação entre Código e Segredos.....                            | 54 |
| 23. Evidências de Funcionamento .....                                  | 54 |
| 23.1 Evidências e finalidades .....                                    | 54 |
| 23.2 Conexão HTTPS.....                                                | 54 |
| 23.3 Redirecionamento para HTTPS .....                                 | 55 |
| 23.4 Criptografia em Repouso.....                                      | 55 |
| 24. Matriz de Atendimento aos Requisitos .....                         | 55 |
| 25. Hardening de Trânsito, HTTPS/TLS e Cabeçalhos HTTP .....           | 56 |
| 26. Relatório de Testes de Intrusão e Segurança (Pentest / DAST) ..... | 57 |
| 27. Governança e Conformidade com a LGPD .....                         | 58 |

|                                                                                   |    |
|-----------------------------------------------------------------------------------|----|
| 27.1 Tabela de Mapeamento de Dados (RoPA - Record of Processing Activities) ..... | 58 |
| 27.2 Matriz dos Direitos do Titular (Artigo 18 da LGPD) .....                     | 61 |
| 28. Modelagem de Ameaças (STRIDE) e Auditoria Imutável .....                      | 62 |
| 28.1 Identificação dos ativos do sistema .....                                    | 62 |
| 28.2 Identificação de Ameaças e Vulnerabilidades .....                            | 64 |
| 28.3 Matriz de Riscos e Contramedidas .....                                       | 67 |
| 29. Resumo Científico Estruturado (200 a 300 palavras) .....                      | 69 |
| 30. Matriz de Rastreabilidade de Requisitos (RTM Geral) .....                     | 70 |
| 31. Referências .....                                                             | 71 |

## **Visão Geral do Sistema**

O **ECOA** é uma plataforma web voltada ao planejamento terapêutico e ao acompanhamento fonoaudiológico infantil. O sistema foi concebido para integrar, em um único ambiente digital, atividades relacionadas ao cadastro e acompanhamento de crianças, elaboração de planos terapêuticos, prescrição de exercícios de estimulação da fala, registro da evolução e acompanhamento das informações necessárias à gestão clínica.

A proposta surge da necessidade de reduzir a fragmentação de informações normalmente distribuídas entre registros informais, orientações verbais, documentos isolados e diferentes meios de comunicação. Nesse contexto, o ECOA busca estruturar o acompanhamento terapêutico por meio de informações organizadas, rastreáveis e associadas ao respectivo paciente, profissional e plano terapêutico.

Além das funcionalidades clínicas, o sistema incorpora mecanismos de segurança da informação e proteção de dados pessoais, considerando que parte das informações processadas corresponde a dados relacionados à saúde de crianças. A arquitetura contempla mecanismos de autenticação, autenticação em dois fatores, controle de acesso por perfil, proteção de credenciais, criptografia de dados sensíveis, comunicação segura, auditoria e funcionalidades destinadas ao exercício de direitos relacionados à proteção de dados.

Este Documento de Visão apresenta o ECOA em nível geral, descrevendo seu propósito, contexto, usuários, principais capacidades, limites e características fundamentais. O documento busca fornecer uma compreensão comum do sistema antes da apresentação dos artefatos técnicos detalhados de requisitos, arquitetura, segurança, criptografia, modelagem de ameaças e conformidade com a LGPD.

## **Especificação do Sistema (SRS / ERS)**

A Especificação de Requisitos de Software (SRS/ERS) do **ECOA** estabelece os limites funcionais e técnicos da solução, definindo as funcionalidades contempladas, as restrições adotadas e os elementos que não integram a versão proposta. A delimitação é estruturada de forma compatível com as diretrizes de especificação de requisitos adotadas no projeto, tendo como referência os padrões **ISO/IEC/IEEE 29148** e **IEEE 830**.

### **1.1 Declaração e Delimitação de Escopo (Scope Statement)**

**Objetivo Geral:** Projetar, documentar e implementar o **ECOIA**, uma plataforma computacional web segura voltada ao planejamento terapêutico e ao acompanhamento fonoaudiológico infantil, integrando cadastro e gerenciamento de pacientes, elaboração de planos terapêuticos, prescrição de exercícios e registro da evolução clínica. A solução contempla mecanismos de autenticação, controle de acesso, proteção criptográfica, auditoria e tratamento de dados pessoais e dados pessoais sensíveis, em conformidade com os requisitos de segurança e proteção de dados estabelecidos para o projeto.

### **Escopo Positivo (In-Scope):**

- 1. Módulo de Autenticação e Gestão de Credenciais**, contemplando cadastro e autenticação dos usuários, armazenamento de senhas por hash criptográfico Argon2id com salt, autenticação em dois fatores (2FA), gerenciamento e expiração de sessões, invalidação da sessão no logout e limitação de tentativas de autenticação (*rate limiting*).
- 2. Módulo de Recuperação de Senha**, responsável pelo processo de redefinição de credenciais mediante tokens temporários, com prazo de expiração, uso único, tratamento de tokens inválidos ou expirados e registro dos eventos relacionados ao processo.
- 3. Módulo de Cadastro e Acompanhamento da Criança**, destinado ao registro das informações necessárias à identificação da criança e de seu responsável legal, observando o princípio de minimização de dados adotado pelo sistema.
- 4. Módulo de Plano Terapêutico Fonoaudiológico**, destinado à elaboração e ao acompanhamento do plano terapêutico da criança, incluindo registro do tipo de dificuldade de fala, fonemas-alvo, metas terapêuticas e informações necessárias à condução do acompanhamento pelo profissional responsável.
- 5. Biblioteca de Exercícios de Estimulação da Fala**, constituída por exercícios organizados por fonema e dificuldade, contendo instruções e suporte a materiais em vídeo para orientar a realização das atividades terapêuticas.
- 6. Acompanhamento e Registro de Evolução**, destinado ao registro estruturado da evolução da criança e das atividades realizadas, possibilitando a construção de histórico associado ao respectivo plano terapêutico e aos exercícios prescritos.
- 7. Recursos de Colaboração Clínica**, permitindo o registro de comentários relacionados aos planos terapêuticos e exercícios, de acordo com as permissões atribuídas aos perfis profissionais previstos no sistema.

**8. Controle de Acesso por Perfil**, contemplando os perfis de Fonoaudiólogo, Coordenador Clínico, Administrador de TI e Responsável Legal, com restrições de acesso definidas conforme as atribuições de cada usuário e a necessidade de acesso às informações. O Administrador de TI permanece restrito às funções técnicas e administrativas, sem acesso aos dados clínicos sensíveis das crianças, conforme definido no modelo de negócio do ECOA.

**9. Painel de Gestão Clínica**, destinado ao Coordenador Clínico, proporcionando visão consolidada das informações necessárias ao acompanhamento dos planos e registros sob sua responsabilidade, respeitando as restrições de acesso e edição estabelecidas para esse perfil.

**10. Módulo de Criptografia e Comunicação Segura**, contemplando comunicação por HTTPS/TLS, bloqueio ou redirecionamento de conexões não seguras e criptografia dos dados clínicos sensíveis armazenados em repouso. A implementação atual utiliza os recursos criptográficos do Laravel para proteção dos campos clínicos definidos pelo projeto.

**11. Módulo de Governança e Conformidade com a LGPD**, contemplando inventário e finalidade dos dados tratados, registro e versionamento do consentimento, revogação, consulta aos dados do titular, exportação e exclusão/anonimização, além da documentação do fluxo de atendimento aos direitos previstos no projeto.

**12. Subsistema de Auditoria e Logs**, responsável pelo registro de eventos relevantes de segurança, incluindo autenticações, falhas de login e falhas de 2FA, bem como mecanismos destinados à verificação da integridade dos registros e à análise de eventos de segurança.

**13. Artefatos Técnico-Científicos**, abrangendo a documentação de engenharia de software, segurança da informação e LGPD, modelagem de arquitetura e dados, análise de ameaças e riscos, evidências e resultados dos testes de segurança, resumo científico estruturado, pôster científico e materiais destinados à apresentação do projeto.

### **Escopo Negativo (Out-of-Scope):**

- Diagnóstico fonoaudiológico automatizado, apoio à decisão diagnóstica ou utilização de **Inteligência Artificial** para determinar diagnósticos, prognósticos ou condutas terapêuticas;

- Desenvolvimento de aplicativo móvel independente para realização dos exercícios domiciliares, uma vez que as funcionalidades destinadas ao acompanhamento e à prática das atividades permanecem integradas à plataforma web;
- Integração com prontuários eletrônicos de saúde, sistemas hospitalares, sistemas de convênios ou outras plataformas clínicas externas;
- Sistemas de faturamento, cobrança, contabilidade, gestão financeira ou processamento de pagamentos da clínica;
- Autenticação federada por serviços externos ou redes sociais, incluindo mecanismos de *Single Sign-On* ou OAuth com terceiros;
- Módulo próprio de comunicação instantânea entre profissionais e responsáveis legais, permanecendo, nesta versão, a comunicação externa à plataforma por meio dos canais já utilizados pela clínica;
- Diagnósticos médicos, histórico geral de saúde, prontuário médico completo ou coleta de documentos de identificação da criança que não sejam necessários às finalidades específicas do acompanhamento fonoaudiológico;
- Implantação ou gerenciamento de infraestrutura física própria e redundante de servidores ou *datacenters*, não fazendo parte do escopo do ECOA a administração da infraestrutura física subjacente à hospedagem da aplicação.

## 1.2 Requisitos Funcionais (RF)

| Código | Requisito Funcional                | Descrição Comportamental Detalhada                                                                                                                                                                                                         | Item do Checklist    |
|--------|------------------------------------|--------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|----------------------|
| Código | Requisito Funcional                | Descrição Comportamental Detalhada                                                                                                                                                                                                         | Item do Checklist    |
| RF-01  | Cadastro e Proteção de Credenciais | O sistema deve permitir o cadastro de usuários mediante validação dos dados obrigatórios e deve transformar a senha informada em hash criptográfico Argon2id antes de sua persistência. O processo de hashing deve utilizar salt aleatório | Itens 1.1, 1.3 e 1.4 |

|              |                                                              |                                                                                                                                                                                                                                                                                                                             |                        |
|--------------|--------------------------------------------------------------|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|------------------------|
|              |                                                              | e exclusivo incorporado à representação do hash, impedindo o armazenamento da senha original em texto puro.                                                                                                                                                                                                                 |                        |
| <b>RF-02</b> | <b>Autenticação Primária</b>                                 | O sistema deve autenticar o usuário mediante e-mail e senha, verificando a credencial informada contra o hash persistido no banco de dados. Credenciais inválidas devem impedir a criação de uma sessão autenticada e gerar o tratamento correspondente de falha de autenticação.                                           | Itens <b>1.1 e 1.7</b> |
| <b>RF-03</b> | <b>Autenticação em Dois Fatores (2FA)</b>                    | O sistema deve disponibilizar autenticação em dois fatores baseada em TOTP. Quando o 2FA estiver habilitado e confirmado para a conta, o código temporário deve ser solicitado exclusivamente após a validação das credenciais primárias, sendo a autenticação concluída somente após a validação correta do segundo fator. | Itens <b>1.5 e 1.6</b> |
| <b>RF-04</b> | <b>Proteção contra Tentativas Excessivas de Autenticação</b> | O sistema deve limitar tentativas consecutivas de autenticação e validação do segundo fator, aplicando rate limiting às operações protegidas. Ao atingir o limite configurado, novas tentativas devem ser temporariamente impedidas até a                                                                                   | Item <b>1.11</b>       |

|              |                                                        |                                                                                                                                                                                                                                                                                                                                                                              |                                  |
|--------------|--------------------------------------------------------|------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|----------------------------------|
|              |                                                        | liberação determinada pelo mecanismo de controle.                                                                                                                                                                                                                                                                                                                            |                                  |
| <b>RF-05</b> | <b>Gestão de Sessão e Logout</b>                       | O sistema deve manter sessões autenticadas com tempo de expiração configurável por inatividade. Ao realizar logout, deve encerrar a autenticação vigente, invalidar a sessão anterior e renovar os mecanismos necessários à proteção das requisições subsequentes.                                                                                                           | Itens <b>1.9 e 1.10</b>          |
| <b>RF-06</b> | <b>Solicitação de Recuperação de Senha</b>             | O sistema deve permitir que o usuário solicite a redefinição da senha por meio do e-mail associado à conta. Deve ser gerado token criptograficamente seguro, armazenado de forma protegida, com período de validade limitado, e a solicitação deve ser registrada em log. A resposta da interface não deve permitir inferir indevidamente a existência de determinada conta. | Itens <b>2.1, 2.2, 2.3 e 2.6</b> |
| <b>RF-07</b> | <b>Validação e Invalidação do Token de Recuperação</b> | O sistema deve validar o token apresentado durante a redefinição de senha, rejeitando tokens inválidos, expirados ou anteriormente utilizados. Após uma redefinição concluída com sucesso, o token deve ser invalidado para impedir reutilização, e o resultado da                                                                                                           | Itens <b>2.4, 2.5 e 2.7</b>      |

|              |                                       |                                                                                                                                                                                                                                                                                                    |                             |
|--------------|---------------------------------------|----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|-----------------------------|
|              |                                       | operação deve ser registrado em log.                                                                                                                                                                                                                                                               |                             |
| <b>RF-08</b> | <b>Registro de Consentimento LGPD</b> | O sistema deve solicitar manifestação explícita do usuário quando aplicável ao tratamento fundamentado em consentimento, associando o registro à finalidade declarada e armazenando, no mínimo, usuário, versão do termo e data/hora do aceite, de forma a possibilitar sua posterior comprovação. | Itens <b>4.4, 4.5 e 4.7</b> |
| <b>RF-09</b> | <b>Revogação de Consentimento</b>     | O sistema deve permitir que o usuário revogue um consentimento anteriormente concedido. A revogação deve interromper a condição de consentimento ativo e registrar a data da revogação, preservando o histórico necessário a rastreabilidade do processo.                                          | Item <b>4.6</b>             |
| <b>RF-10</b> | <b>Consulta aos Dados Pessoais</b>    | O sistema deve disponibilizar área autenticada na qual o usuário possa consultar os dados pessoais associados à sua conta e os respectivos registros de consentimento mantidos pela plataforma, respeitando suas permissões de acesso.                                                             | Item <b>4.8</b>             |
| <b>RF-11</b> | <b>Exportação de Dados</b>            | O sistema deve permitir que o usuário solicite e obtenha cópia de seus dados pessoais em formato estruturado e legível por                                                                                                                                                                         | Item <b>4.9</b>             |

|              |                                                  |                                                                                                                                                                                                                                                                                                                                            |                        |
|--------------|--------------------------------------------------|--------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|------------------------|
|              |                                                  | máquina, utilizando, na implementação atual, arquivo JSON gerado para download.                                                                                                                                                                                                                                                            |                        |
| <b>RF-12</b> | <b>Exclusão e Anonimização de Dados Pessoais</b> | O sistema deve permitir que o usuário solicite a exclusão de seus dados pessoais. Quando a eliminação física não for compatível com requisitos de integridade ou retenção aplicáveis, o sistema deve anonimizar os campos identificáveis e aplicar exclusão lógica aos registros previstos, encerrando posteriormente a sessão do usuário. | Item <b>4.10</b>       |
| <b>RF-13</b> | <b>Registro de Eventos de Auditoria</b>          | O sistema deve registrar eventos relevantes de segurança, incluindo autenticação bem-sucedida, falhas de autenticação e falhas de validação do 2FA. Os registros devem conter informações suficientes para rastreabilidade do evento, tais como tipo, usuário ou identificador relacionado, endereço IP e data/hora.                       | Itens <b>5.1 e 5.2</b> |
| <b>RF-14</b> | <b>Verificação de Integridade dos Logs</b>       | O sistema deve manter os registros da trilha de auditoria encadeados por mecanismos criptográficos de integridade e disponibilizar funcionalidade capaz de verificar a cadeia, identificando alterações                                                                                                                                    | Item <b>5.3</b>        |

|              |                                                 |                                                                                                                                                                                                                                                                                                 |                                 |
|--------------|-------------------------------------------------|-------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|---------------------------------|
|              |                                                 | incompatíveis com os valores originalmente registrados.                                                                                                                                                                                                                                         |                                 |
| <b>RF-15</b> | <b>Consulta e Análise dos Logs de Auditoria</b> | O sistema deve disponibilizar, aos perfis autorizados, interface para consulta dos eventos de auditoria e apresentação de informações agregadas, incluindo a identificação de sucessivas falhas de autenticação por endereço IP para apoio à análise de possíveis comportamentos suspeitos.     | Item <b>5.4</b>                 |
| <b>RF-16</b> | <b>Gestão de Perfis e Controle de Acesso</b>    | O sistema deve identificar o perfil associado a cada usuário e aplicar as permissões correspondentes às funções de <b>Fonoaudiólogo, Coordenador Clínico, Administrador de TI e Responsável Legal</b> , impedindo acesso a funcionalidades ou informações não autorizadas ao respectivo perfil. | ítems <b>6.1, 6.3 e 8.5</b>     |
| <b>RF-17</b> | <b>Cadastro de Responsável Legal</b>            | O sistema deve permitir o cadastro dos dados necessários à identificação e ao contato do responsável legal, vinculando-o à respectiva conta de usuário e às crianças sob sua responsabilidade, conforme as permissões estabelecidas para esse perfil.                                           | ítems <b>6.1 e 8.5</b>          |
| <b>RF-18</b> | <b>Cadastro e Vinculação da Criança</b>         | O sistema deve permitir o cadastro da criança utilizando apenas os dados definidos como                                                                                                                                                                                                         | Ítems <b>4.1, 4.2, 4.3; 6.1</b> |

|              |                                                      |                                                                                                                                                                                                                                                            |                             |
|--------------|------------------------------------------------------|------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|-----------------------------|
|              |                                                      | necessários ao acompanhamento fonoaudiológico e deve vinculá-la ao respectivo responsável legal, possibilitando posteriormente sua associação ao plano terapêutico e aos profissionais autorizados.                                                        |                             |
| <b>RF-19</b> | <b>Gestão do Plano Terapêutico Fonoaudiológico</b>   | O sistema deve permitir ao fonoaudiólogo autorizado criar, consultar e atualizar o plano terapêutico da criança, registrando informações como tipo de dificuldade de fala, fonemas-alvo, metas terapêuticas, situação do plano e profissional responsável. | itens <b>6.1 e 8.5</b>      |
| <b>RF-20</b> | <b>Biblioteca de Exercícios de Estimulação</b>       | O sistema deve manter biblioteca de exercícios de estimulação da fala, possibilitando o cadastro e a consulta de atividades categorizadas por características como fonema e dificuldade, contendo instruções que auxiliem sua execução.                    | itens <b>6.1 e 8.5</b>      |
| <b>RF-21</b> | <b>Gerenciamento de Material Audiovisual</b>         | O sistema deve permitir associar materiais audiovisuais aos exercícios terapêuticos, possibilitando sua apresentação como recurso de orientação para execução das atividades prescritas.                                                                   | itens <b>6.1 e 8.5</b>      |
| <b>RF-22</b> | <b>Prescrição de Exercícios ao Plano Terapêutico</b> | O sistema deve permitir ao profissional autorizado selecionar exercícios existentes na biblioteca                                                                                                                                                          | itens <b>6.1, 6.3 e 8.5</b> |

|              |                                                      |                                                                                                                                                                                                                                                 |                             |
|--------------|------------------------------------------------------|-------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|-----------------------------|
|              |                                                      | e associá-los ao plano terapêutico da criança, registrando a atribuição e as orientações profissionais pertinentes.                                                                                                                             |                             |
| <b>RF-23</b> | <b>Registro de Realização de Exercícios</b>          | O sistema deve permitir registrar a realização dos exercícios prescritos, mantendo informações necessárias ao acompanhamento da atividade, incluindo o exercício relacionado, resultado ou situação de realização e observações pertinentes.    | itens <b>6.1 e 8.5</b>      |
| <b>RF-24</b> | <b>Diário de Evolução Fonoaudiológica</b>            | O sistema deve permitir o registro cronológico da evolução da criança, vinculando observações ao acompanhamento terapêutico e mantendo histórico estruturado que possa subsidiar a avaliação e o ajuste do plano pelo profissional responsável. | itens <b>6.1, 6.3 e 8.5</b> |
| <b>RF-25</b> | <b>Comentários Relacionados aos Exercícios</b>       | O sistema deve permitir o registro de comentários ou observações vinculados aos exercícios terapêuticos, conforme as permissões do usuário, possibilitando contextualizar a orientação ou execução da atividade.                                | itens <b>6.1 e 8.5</b>      |
| <b>RF-26</b> | <b>Acesso do Responsável Legal ao Acompanhamento</b> | O sistema deve permitir que o Responsável Legal autenticado consulte exclusivamente as informações das crianças vinculadas à sua                                                                                                                | itens <b>6.3 e 8.5</b>      |

|              |                                                 |                                                                                                                                                                                                                                                                                                                 |                                  |
|--------------|-------------------------------------------------|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|----------------------------------|
|              |                                                 | responsabilidade, incluindo exercícios e informações de evolução disponibilizadas para acompanhamento, sem acesso aos dados de outras crianças ou famílias.                                                                                                                                                     |                                  |
| <b>RF-27</b> | <b>Restrição de Pacientes por Fonoaudiólogo</b> | O sistema deve permitir que o Fonoaudiólogo consulte e altere informações clínicas apenas das crianças sob sua responsabilidade ou para as quais tenha autorização estabelecida, impedindo acesso indevido aos prontuários terapêuticos de outros profissionais.                                                | itens <b>6.3, 6.8 e 8.5</b>      |
| <b>RF-28</b> | <b>Painel do Coordenador Clínico</b>            | O sistema deve disponibilizar ao Coordenador Clínico uma visão consolidada do acompanhamento clínico, permitindo consultar informações necessárias à gestão dos planos e registros, sem conceder automaticamente permissão para alteração direta dos dados clínicos atribuídos aos fonoaudiólogos responsáveis. | itens <b>6.1, 6.3 e 8.5</b>      |
| <b>RF-30</b> | <b>Segregação do Administrador de TI</b>        | O sistema deve permitir ao Administrador de TI executar as funções técnicas e administrativas previstas para seu perfil, impedindo o acesso ao conteúdo clínico sensível de planos terapêuticos, observações de                                                                                                 | itens <b>4.3, 6.6, 6.8 e 8.5</b> |

|  |  |                                                        |  |
|--|--|--------------------------------------------------------|--|
|  |  | evolução e demais informações terapêuticas protegidas. |  |
|--|--|--------------------------------------------------------|--|

### 1.3 Requisitos Não Funcionais (RNF)

| Código        | Categoria                             | Especificação Técnica e Critério de Aceite                                                                                                                                                                                                                                                                                                                                                                                                              | Item do Checklist                |
|---------------|---------------------------------------|---------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|----------------------------------|
| <b>RNF-01</b> | Segurança (Hash de Senhas)            | O armazenamento de senhas deve utilizar Argon2id, sem persistência da senha em texto puro. O algoritmo deve empregar salt criptográfico aleatório e exclusivo por hash, incorporado à própria representação Argon2id, e parâmetros de custo explicitamente configurados e documentados. Na configuração atual do ECOA, devem ser comprovados memory = 65536 KB, time = 4 e parallelism = 2, ou eventual configuração posterior devidamente justificada. | Itens <b>1.1, 1.2, 1.3 e 1.4</b> |
| <b>RNF-02</b> | Segurança (Defesa contra Força Bruta) | O sistema deve limitar tentativas consecutivas de autenticação e de validação do segundo fator. Na configuração atual, o mecanismo deve permitir no máximo 5 tentativas por minuto para login e para o desafio 2FA, bloqueando temporariamente novas tentativas após o limite definido.                                                                                                                                                                 | Item <b>1.11</b>                 |
| <b>RNF-03</b> | Segurança (Gestão de Sessões)         | As sessões autenticadas devem possuir tempo de expiração configurável por inatividade e devem ser imediatamente invalidadas após o logout. O tempo de sessão deve ser parametrizável de acordo                                                                                                                                                                                                                                                          | tens <b>1.9 e 1.10</b>           |

|               |                                        |                                                                                                                                                                                                                                                                                                                                                                  |                             |
|---------------|----------------------------------------|------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|-----------------------------|
|               |                                        | com o ambiente de execução e passível de comprovação por testes funcionais.                                                                                                                                                                                                                                                                                      |                             |
| <b>RNF-04</b> | Segurança<br>(Comunicação em Trânsito) | Toda comunicação entre cliente e aplicação em ambiente de produção deve ocorrer exclusivamente por HTTPS/TLS. Requisições realizadas por HTTP devem ser redirecionadas ou bloqueadas, e os cookies de sessão devem ser transmitidos somente por conexão segura. A aplicação deve reconhecer corretamente conexões HTTPS quando executada atrás de proxy reverso. | Itens <b>3.1, 3.2 e 3.3</b> |
| <b>RNF-05</b> | Segurança<br>(Criptografia em Repouso) | Os dados clínicos classificados como pessoais sensíveis devem ser armazenados de forma cifrada. O ECOA deve utilizar mecanismo criptográfico simétrico adequado, baseado na implementação atual em AES-256-CBC com autenticação de mensagens, aplicado aos campos clínicos definidos na arquitetura da aplicação.                                                | Itens <b>3.4 e 3.5</b>      |
| <b>RNF-06</b> | Segurança<br>(Gestão de Chaves)        | As chaves e os segredos utilizados pelos mecanismos criptográficos não devem ser incluídos no código-fonte nem versionados no repositório. A APP_KEY e demais segredos devem permanecer em variáveis de ambiente ou mecanismo equivalente de configuração segura, com acesso restrito ao ambiente de execução.                                                   | Item <b>3.6</b>             |
| <b>RNF-07</b> | Segurança<br>(Controle de Acesso)      | O sistema deve aplicar controle de acesso de acordo com o perfil do usuário e o princípio do menor privilégio. Cada perfil deve acessar somente as funcionalidades e                                                                                                                                                                                             | Itens <b>4.3, 6.6 e 6.8</b> |

|               |                                         |                                                                                                                                                                                                                                                                                                                                        |                             |
|---------------|-----------------------------------------|----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|-----------------------------|
|               |                                         | informações necessárias às suas atribuições. O Administrador de TI não deve acessar conteúdo clínico sensível, e o Fonoaudiólogo deve ter acesso somente aos pacientes sob sua responsabilidade ou autorização.                                                                                                                        |                             |
| <b>RNF-08</b> | Legalidade e Privacidade (LGPD)         | A arquitetura e o tratamento de dados devem observar os princípios de finalidade, adequação e necessidade/minimização, mantendo somente os dados compatíveis com as finalidades declaradas do acompanhamento fonoaudiológico. Cada categoria de dado pessoal coletado deve possuir finalidade e fundamento de tratamento documentados. | Itens <b>4.1, 4.2 e 4.3</b> |
| <b>RNF-09</b> | Privacidade (Dados Infantis e de Saúde) | Os dados referentes às crianças e ao acompanhamento fonoaudiológico devem receber proteção compatível com sua natureza sensível. O sistema deve restringir sua exposição aos usuários autorizados e evitar a coleta de informações cadastrais ou clínicas que não sejam necessárias às finalidades definidas para o ECOA.              | Itens <b>4.1, 4.2 e 4.3</b> |
| <b>RNF-10</b> | Confiabilidade (Integridade dos Logs)   | Os registros da trilha de auditoria devem possuir mecanismo de proteção contra adulteração silenciosa. A implementação deve manter encadeamento criptográfico entre os eventos registrados, permitindo detectar modificações posteriores durante a verificação da integridade da cadeia de logs.                                       | Item <b>5.3</b>             |

|               |                                   |                                                                                                                                                                                                                                                                                                                                               |                             |
|---------------|-----------------------------------|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|-----------------------------|
| <b>RNF-11</b> | Auditabilidade e Rastreabilidade  | Os eventos relevantes de segurança devem registrar informações suficientes para posterior análise, incluindo, quando aplicável, tipo de evento, usuário ou identificador associado, endereço IP e data/hora. Os registros devem permitir a investigação de ocorrências como autenticações malsucedidas e possíveis tentativas de força bruta. | Itens <b>5.1, 5.2 e 5.4</b> |
| <b>RNF-12</b> | Usabilidade e Responsividade      | A interface web deve ser responsiva e manter condições adequadas de leitura e utilização em diferentes dimensões de tela. Formulários, menus, tabelas e demais componentes devem preservar consistência visual e permitir acesso claro às funcionalidades disponibilizadas para cada perfil de usuário.                                       | itens <b>6.1 e 8.5</b>      |
| <b>RNF-13</b> | Arquitetura e Manutenibilidade    | A aplicação deve manter separação de responsabilidades compatível com a arquitetura MVC, preservando a distinção entre camada de apresentação, lógica da aplicação e persistência de dados. Alterações em uma funcionalidade não devem exigir modificações indevidas em componentes sem relação direta com o requisito alterado.              | Itens <b>6.1, 6.2 e 6.3</b> |
| <b>RNF-14</b> | Testabilidade e Evidenciabilidade | Os mecanismos críticos de segurança e proteção de dados devem ser passíveis de teste e produzir evidências reproduzíveis. Para cada teste relevante devem ser registrados o cenário avaliado, o comportamento esperado, o resultado obtido e a respectiva evidência técnica.                                                                  | Itens <b>6.9 e 6.10</b>     |

|               |                               |                                                                                                                                                                                                                                                                                                                                           |                               |
|---------------|-------------------------------|-------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|-------------------------------|
| <b>RNF-15</b> | Rastreabilidade de Requisitos | Os requisitos funcionais e não funcionais devem possuir correspondência identificável com implementação, testes, evidências e itens do checklist, permitindo sua posterior consolidação na Matriz de Rastreabilidade de Requisitos (RTM).                                                                                                 | Itens <b>6.1 a 6.10 e 8.5</b> |
| <b>RNF-16</b> | Rigor Técnico-Científico      | A documentação deve fundamentar as principais decisões de engenharia de software, segurança da informação, criptografia e proteção de dados por meio de artigos científicos, legislação, normas técnicas, RFCs ou documentação técnica reconhecida. As referências devem ser apresentadas conforme o padrão acadêmico adotado no projeto. | Itens <b>6.11 e 6.12</b>      |

#### 1.4 Regra de Negócio (RN)

- **RN-01 (Sequenciamento da Autenticação):** Quando o 2FA estiver ativo, o acesso ao sistema somente será liberado após a validação do primeiro fator e, posteriormente, do código TOTP.
- **RN-02 (Validade do Token de Recuperação):** O token de recuperação de senha terá validade máxima de 60 minutos, deverá ser invalidado após o primeiro uso e rejeitado quando expirado, inválido ou já utilizado.
- **RN-03 (Proteção contra Enumeração de Contas):** O fluxo de recuperação de senha não deverá informar se o e-mail fornecido está ou não cadastrado no sistema.
- **RN-04 (Minimização e Finalidade):** Somente poderão ser coletados dados necessários às finalidades previamente definidas para o funcionamento e acompanhamento fonoaudiológico no ECOA.
- **RN-05 (Limitação ao Escopo Fonoaudiológico):** O sistema não deverá armazenar informações clínicas ou cadastrais que não sejam necessárias ao acompanhamento fonoaudiológico.

- **RN-06 (Vínculo do Responsável Legal):** Toda criança deverá estar vinculada a um responsável legal, que poderá acessar apenas os dados das crianças sob sua responsabilidade.
- **RN-07 (Acesso do Fonoaudiólogo):** O fonoaudiólogo deverá acessar e alterar apenas os dados clínicos dos pacientes sob sua responsabilidade ou autorização.
- **RN-08 (Acesso do Coordenador Clínico):** O Coordenador Clínico poderá consultar informações necessárias à gestão clínica, sem permissão automática para alterar os registros do fonoaudiólogo responsável.
- **RN-09 (Segregação do Administrador de TI):** O Administrador de TI deverá atuar apenas em funções técnicas e administrativas, sem acesso ao conteúdo clínico sensível dos pacientes.
- **RN-10 (Vínculo do Plano Terapêutico):** Todo plano terapêutico deverá estar associado a uma criança e a um fonoaudiólogo responsável.
- **RN-11 (Vinculação de Exercícios):** Os exercícios prescritos deverão estar associados ao respectivo plano terapêutico e poderão conter materiais de orientação, podendo ou não incluir vídeos.
- **RN-12 (Registro da Evolução):** Os registros de evolução deverão permanecer vinculados ao acompanhamento terapêutico da criança, preservando seu histórico.
- **RN-13 (Consentimento e Finalidade):** Quando aplicável, o consentimento deverá ser explícito, associado a uma finalidade e registrado com data e versão do termo aceito.
- **RN-14 (Revogação do Consentimento):** A revogação deverá registrar sua data sem excluir o histórico do consentimento anteriormente concedido.
- **RN-15 (Exclusão e Anonimização):** A solicitação de exclusão deverá anonimizar os dados identificáveis e aplicar exclusão lógica quando necessária à integridade dos registros.
- **RN-16 (Preservação da Auditoria):** A exclusão ou anonimização de um usuário não deverá eliminar os registros de auditoria necessários à rastreabilidade das operações.
- **RN-17 (Integridade dos Logs):** Os registros de auditoria deverão possuir mecanismo que permita detectar alterações posteriores em sua cadeia de integridade.
- **RN-18 (Acesso aos Logs):** A consulta aos registros de auditoria deverá ser restrita aos perfis autorizados, atualmente Coordenador Clínico e Administrador de TI.
- **RN-19 (Registro de Eventos de Segurança):** Eventos de autenticação, falhas de login, falhas de 2FA e recuperação de senha deverão gerar registros para posterior auditoria.

## 1.5 Casos de Uso de Engenharia de Software

### UC-01 – Efetuar o Login utilizando a verificação de 2 fatores

**Autores:** Responsável legal da criança, fonoaudiólogo, coordenador clínico e administrador de TI.

**Fluxo Principal:**

1. O usuário informa suas credenciais de acesso;
2. O sistema verifica o login e a senha;
3. O sistema verifica se os dados inseridos estão corretos (1º fator);
4. Após o 1º fator ser aceito, um QR code é exibido na tela;
5. O usuário escaneia o QR code com a câmera do celular;
6. O sistema gera um token temporário e o envia para o app autenticador;
7. O usuário insere o token de 6 dígitos no aplicativo autenticador;
8. O sistema valida o token e inicia a sessão do usuário com registro de auditoria.

**Exceções:** Credenciais incorretas impedem o acesso e exibem uma mensagem de erro; muitas tentativas falhas acarretam um erro.

### UC-02 – Realizar o Cadastro

**Autores:** Responsável legal da criança, fonoaudiólogo, coordenador clínico e administrador de TI.

**Fluxo Principal:**

1. O usuário seleciona a opção de cadastrar-se;
2. O sistema solicita os dados necessários para a criação da conta;
3. O usuário insere os dados solicitados, seleciona o perfil de acesso e concorda com os termos de uso e a política de privacidade;
4. O sistema valida as informações e se o usuário concordou com os termos necessários;
5. O sistema cria a conta e confirma o cadastro.

**Exceções:** Dados solicitados ausentes ou inválidos impedem a conclusão do cadastro; não selecionar que concorda com os termos necessários impede a finalização do cadastro; utilizar um e-mail já cadastrado dá erro e não permite finalizar o cadastro.

### UC-03 - Recuperação de Senha

**Autores:** Responsável legal da criança, fonoaudiólogo, coordenador clínico e administrador de TI.

**Fluxo Principal:**

1. O usuário seleciona a opção de recuperar a senha na tela de login;
2. O sistema solicita o e-mail já cadastrado;
3. O usuário insere o e-mail e seleciona a opção de enviar link de recuperação;
4. O sistema envia o link para o e-mail do usuário;
5. O usuário recebe o link e retorna para a página de login.

**UC-04 - Criação do Plano Terapêutico**

**Autores:** Fonoaudiólogo.

**Fluxo Principal:**

1. O usuário seleciona a quem pertencerá o plano a ser criado;
2. O usuário seleciona a opção de criar um plano terapêutico, caso já exista um, ele tem a opção de atualizá-lo;
3. O plano é criado e atribuído para o paciente;
4. O usuário insere os exercícios no plano;
5. O sistema gera um plano de exercícios.

**UC-05 - Realização dos exercícios e comentários**

**Autores:** Responsável pela criança.

**Fluxo Principal:**

1. O usuário acessa o plano de exercícios;
2. A criança realiza o exercício;
3. O usuário realiza um comentário sobre o exercício;
4. O sistema realiza o registro do exercício feito;
5. O sistema armazena o comentário no plano.

**UC-06 - Comentário do plano terapêutico**

**Autores:** Fonoaudiólogo.

**Fluxo Principal:**

1. O usuário verifica o plano terapêutico;
2. O usuário seleciona a opção de fazer um comentário e realiza o comentário desejado;
3. O sistema salva o comentário dentro do plano.

**Exceções:** O usuário não é obrigado a comentar no plano cada vez que acessá-lo.

#### **UC-07 - Verificação da evolução da criança**

**Autores:** Fonoaudiólogo e coordenador clínico.

**Principal fluxo:**

1. O usuário acessa a página do plano terapêutico do paciente;
2. O sistema exibe o plano completo, com os registros e os comentários ordenados por data, criando uma evolução consecutiva do paciente.

#### **UC-08 - Verificação dos Logs**

**Autores:** Coordenador clínico e administrador de TI.

**Fluxo Principal:**

1. O usuário realiza o login e acessa a tela de auditoria;
2. O sistema exibe o total de eventos registrados, o total de falhas de login e os últimos 50 eventos (com e-mail, IP, data e hora, e o hash truncado de cada registro).

#### **UC-09 – Acesso ao Sistema Todo**

**Autores:** Administrador de TI.

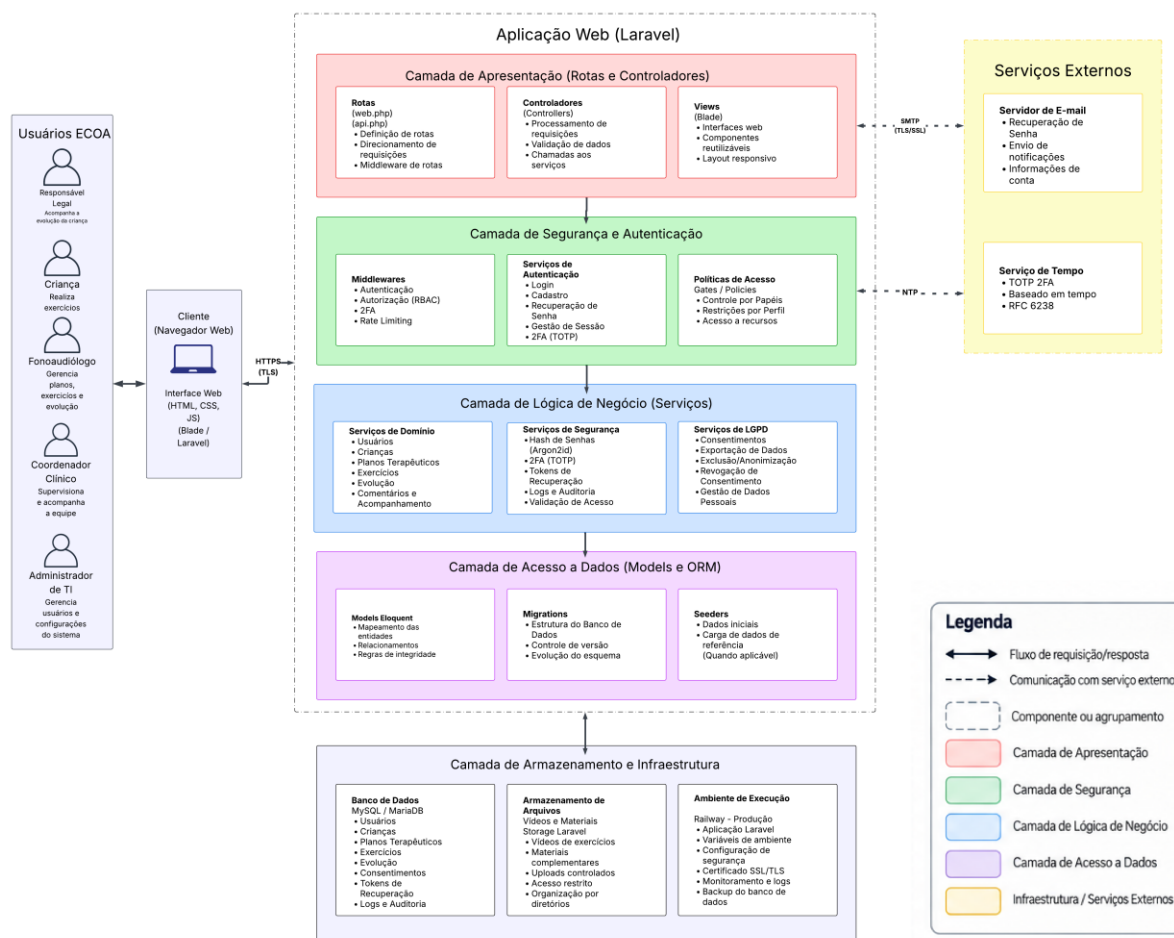
**Fluxo Principal:**

1. O usuário realiza o login no sistema;
2. O sistema dá acesso completo para este usuário.

**Exceções:** O usuário não pode ver nem alterar os dados pessoais dos demais usuários.

### **1.5 Diagrama de Arquitetura**

Diagrama da arquitetura do projeto.



## 2. Fluxos de autenticação e dados documentados

O módulo de autenticação do Ecoa utiliza o **Laravel Fortify** como base para os recursos de autenticação.

O Fortify foi utilizado porque fornece uma implementação consolidada para funcionalidades como login, cadastro, logout, recuperação de senha, autenticação em dois fatores e controle de tentativas de autenticação.

A interface do sistema foi desenvolvida separadamente, utilizando as views Blade do projeto. Dessa forma, o Fortify é responsável principalmente pela lógica de autenticação, enquanto as telas e a experiência de utilização foram desenvolvidas de acordo com a identidade visual do Ecoa.

### 2.1 Principais arquivos relacionado à autenticação

| Arquivos | Funções |
|----------|---------|
|----------|---------|

|                                                                    |                                                               |
|--------------------------------------------------------------------|---------------------------------------------------------------|
| <a href="#"><u>app/Providers/FortifyServiceProvider.php</u></a>    | Configuração dos serviços de autenticação e Rate Limiters.    |
| <a href="#"><u>app/Actions/Fortify/CreateNewUser.php</u></a>       | Responsável pela criação de novos usuários.                   |
| <a href="#"><u>app/Models/User.php</u></a>                         | Model de usuário e configuração relacionada ao 2FA.           |
| <a href="#"><u>app/Http/Controllers/SecurityController.php</u></a> | Exibição da área de segurança da conta.                       |
| <a href="#"><u>resources/views/auth/</u></a>                       | Views de login, cadastro, recuperação de senha e desafio 2FA. |
| <a href="#"><u>resources/views/security.blade.php</u></a>          | Interface de gerenciamento da autenticação em dois fatores.   |
| <a href="#"><u>config/fortify.php</u></a>                          | Configuração dos recursos disponibilizados pelo Fortify.      |
| <a href="#"><u>config/hashing.php</u></a>                          | Configuração do algoritmo utilizado para o hash das senhas.   |
| <a href="#"><u>config/session.php</u></a>                          | Configuração do tempo de duração das sessões.                 |

## 2.2 Fluxo de autenticação

O sistema possui diferentes etapas de autenticação, dependendo da configuração de segurança da conta.

- **Cadastro:** No cadastro, o usuário fornece nome, e-mail e senha. Os dados são validados pelo Laravel Fortify e a senha é submetida ao mecanismo de hashing antes de sua persistência.

Usuário



Tela de cadastro



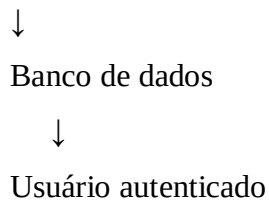
Laravel Fortify



Validação dos dados

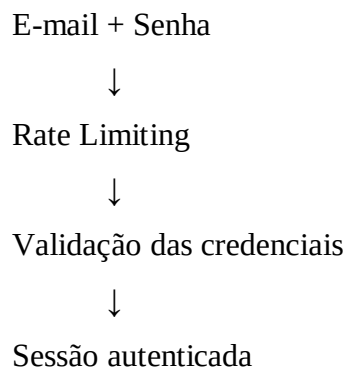


Hash da senha



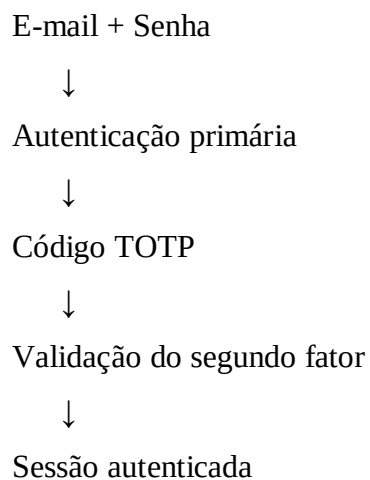
## 2.3 Login sem 2FA

Quando a autenticação em dois fatores não está habilitada, o sistema valida as credenciais e, em caso de sucesso, estabelece uma sessão autenticada.



## 2.4 Login com 2FA

Quando a conta possui 2FA ativo e confirmado, a autenticação ocorre em duas etapas:



O acesso somente é concluído após a validação da senha e do segundo fator.

## 2.5 Ativação do 2FA

A ativação é realizada pela área de segurança da conta. Após nova confirmação da senha, o sistema gera o segredo TOTP e apresenta um QR Code para configuração em aplicativo autenticador. O mecanismo somente é confirmado após a validação de um código temporário válido.

O sistema também disponibiliza códigos de recuperação para situações em que o aplicativo autenticador esteja indisponível.

## 2.6 Logout

O logout encerra a autenticação, invalida a sessão vigente e regenera o token CSRF.

Usuário autenticado



POST /logout



Encerramento da autenticação



Invalidação da sessão



Regeneração do token CSRF

Essas operações impedem a continuidade normal da sessão anterior após o encerramento do acesso.

## 3. Proteção e Armazenamento de Senhas

### 3.1 Algoritmo de Hash

O ECOA utiliza **Argon2id** para o armazenamento das senhas dos usuários.

O mecanismo é configurado em:

config/hashing.php

A utilização de hashing elimina a necessidade de armazenar a senha original no banco de dados.

### 3.2 Parâmetros de Custo

Os parâmetros observados na configuração do projeto são:

| Parâmetro | Valor    | Finalidade                            |
|-----------|----------|---------------------------------------|
| memory    | 65536 KB | Memória utilizada pelo algoritmo      |
| time      | 4        | Custo temporal da operação            |
| threads   | 1        | Grau de paralelismo                   |
| verify    | true     | Verificação dos parâmetros utilizados |

Esses parâmetros aumentam o custo computacional necessário para tentativas sucessivas de descoberta de senha e devem ser avaliados em função da capacidade do ambiente de execução.

### 3.3 Salt Criptográfico

O Argon2id utiliza um **salt aleatório** durante a geração do hash.

Esse salt é gerado automaticamente pelo mecanismo de hashing e não precisa ser criado manualmente pela aplicação.

Consequentemente, duas contas que utilizem a mesma senha podem possuir hashes diferentes.

Isso dificulta ataques baseados na comparação direta de hashes e no uso de tabelas pré-computadas.

### 3.4 Persistência do Hash e Salt

O salt é incorporado à própria representação do hash Argon2id, não sendo necessária uma coluna independente no banco de dados.

Estrutura representativa:

```
$argon2id$v=19$m=65536,t=4,p=1$SALT$HASH
```

Essa estrutura reúne a identificação do algoritmo, sua versão, parâmetros de custo, salt e resultado do hash.

## 4. Autenticação em Dois Fatores

Aplicação de tecnologia de login multifatorial.

### 4.1 Implementação

O ECOA utiliza **TOTP — Time-based One-Time Password** como mecanismo de autenticação em dois fatores.

O segundo fator é configurado por meio de aplicativo autenticador e gera códigos temporários utilizados após a autenticação primária.

Senha válida



Desafio 2FA



Código TOTP



Validação



Acesso autorizado

O segredo utilizado pelo TOTP é tratado pelo mecanismo fornecido pelo Laravel Fortify, e o sistema também disponibiliza códigos de recuperação.

A validação do segundo fator ocorre **após** a autenticação por e-mail e senha. Dessa forma, em contas protegidas por 2FA, a senha isoladamente não conclui o processo de autenticação.

## 5. Gerenciamento de Sessões

### 5.1 Duração da Sessão

A duração das sessões é definida em:  
config/session.php

A configuração atualmente documentada é:

```
'lifetime' => (int) env('SESSION_LIFETIME', 1),  
'expire_on_close' => env('SESSION_EXPIRE_ON_CLOSE', false),
```

Durante o desenvolvimento, foi adotado o valor padrão de **1 minuto de inatividade**, com o objetivo de facilitar testes e demonstrações da expiração da sessão. O valor permanece configurável por meio da variável SESSION\_LIFETIME.

## 5.2 Armazenamento das Sessões

O projeto utiliza, por padrão, o driver de sessões em banco de dados:

```
'driver' => env('SESSION_DRIVER', 'database'),
```

As sessões são persistidas na tabela: sessions

## 5.3 Invalidação no Logout

Durante o logout, são executadas operações equivalentes a:

```
Auth::guard('web')->logout();  
$request->session()->invalidate();  
$request->session()->regenerateToken();
```

A invalidação encerra a sessão anterior e a regeneração do token CSRF reduz a possibilidade de reutilização do token anteriormente associado à sessão.

## 6. Proteção contra Tentativas Excessivas de Autenticação

O ECOA utiliza **Rate Limiting** para restringir a frequência de tentativas realizadas nos mecanismos de autenticação.

### 6.1 Login

O limite configurado é de:

5 tentativas por minuto

A chave de controle combina o identificador utilizado no login com o endereço IP de origem. Dessa forma, tentativas excessivas são temporariamente limitadas.

## **6.2 Autenticação em Dois Fatores**

O desafio de 2FA também é limitado a:

5 tentativas por minuto

O controle é associado ao identificador de login mantido na sessão, reduzindo a possibilidade de tentativas automatizadas sucessivas contra o código TOTP.

## **7. Justificativas Técnicas**

### **7.1 Argon2id**

O Argon2id foi adotado por ser um algoritmo de hashing de senhas com suporte a parâmetros de memória e processamento. Essa característica aumenta o custo de ataques baseados em tentativas sucessivas de descoberta de credenciais.

Sua disponibilidade nativa no ambiente PHP/Laravel também permite utilizar uma implementação consolidada, evitando a criação de mecanismos criptográficos próprios.

### **7.2 Parâmetros de Hash**

Os parâmetros memory = 65536 KB, time = 4 e threads = 1 foram configurados de forma a aumentar o custo computacional do hashing sem inviabilizar a utilização normal do sistema. A adequação desses valores depende do ambiente de execução e deve ser avaliada juntamente com o desempenho da aplicação.

### **7.3 TOTP**

O TOTP foi adotado para fornecer uma segunda etapa de autenticação independente da senha. Os códigos possuem validade temporal e podem ser gerados por aplicativos autenticadores sem dependência contínua de serviços de SMS.

### **7.4 Rate Limiting**

O Rate Limiting reduz o número de tentativas que podem ser realizadas em determinado intervalo, diminuindo a viabilidade de ataques automatizados de força bruta contra os mecanismos de autenticação.

## 8. Evidências de Funcionamento

As funcionalidades do módulo foram validadas por meio de testes realizados pela interface da aplicação. As evidências encontram-se no diretório:

docs/evidencias/

| Evidência                           | Arquivo                                                       |
|-------------------------------------|---------------------------------------------------------------|
| Cadastro de usuário                 | <a href="#"><u>cadastro.png</u></a>                           |
| Login realizado                     | <a href="#"><u>login_realizado.png</u></a>                    |
| Argon2id e proteção das credenciais | <a href="#"><u>seguranca_credenciais_argon2id_2fa.png</u></a> |
| Ativação do 2FA                     | <a href="#"><u>ativar_verificacao.png</u></a>                 |
| QR Code para configuração do 2FA    | <a href="#"><u>fa_qrcode.png</u></a>                          |
| Confirmação do 2FA                  | <a href="#"><u>fa_confirmado.png</u></a>                      |
| Fluxo de autenticação               | <a href="#"><u>autenticacao.png</u></a>                       |
| Rate Limiting                       | <a href="#"><u>rate_limit.png</u></a>                         |
| Bloqueio após excesso de tentativas | <a href="#"><u>tela_limit.png</u></a>                         |
| Sessão válida                       | <a href="#"><u>sessao_validada.png</u></a>                    |
| Sessão invalidada                   | <a href="#"><u>sessao_invalidada.png</u></a>                  |

A documentação registra que os testes e respectivas capturas foram mantidos junto ao projeto para permitir a verificação da implementação.

## 9. Matriz de Atendimento aos Requisitos

| Requisito         | Implementação | Evidência                                                     |
|-------------------|---------------|---------------------------------------------------------------|
| 1.1 — Hash seguro | Argon2id      | <a href="#"><u>seguranca_credenciais_argon2id_2fa.png</u></a> |

|                                           |                                                                      |                                                                                              |
|-------------------------------------------|----------------------------------------------------------------------|----------------------------------------------------------------------------------------------|
| <b>1.2 —<br/>Parâmetros de custo</b>      | Memória, tempo e paralelismo configurados                            | <a href="#"><u>seguranca_credenciais_argon2id_2fa.png</u></a>                                |
| <b>1.3 — Salt único</b>                   | Gerado automaticamente pelo Argon2id                                 | <a href="#"><u>seguranca_credenciais_argon2id_2fa.png</u></a>                                |
| <b>1.4 —<br/>Armazenamento seguro</b>     | Hash e informações necessárias armazenados na representação Argon2id | <a href="#"><u>seguranca_credenciais_argon2id_2fa.png</u></a>                                |
| <b>1.5 — 2FA implementado</b>             | TOTP por meio do Laravel Fortify                                     | <a href="#"><u>fa_qrcode.png</u></a>                                                         |
| <b>1.6 — Validação do 2FA</b>             | Segundo fator validado após a autenticação primária                  | <a href="#"><u>fa_confirmado.png</u></a> , <a href="#"><u>autenticacao.png</u></a>           |
| <b>1.7 — Fluxo documentado</b>            | Cadastro, login, 2FA e logout                                        | <a href="#"><u>docs/evidencias/login_realizado.png</u></a>                                   |
| <b>1.8 —<br/>Evidências funcionais</b>    | Capturas dos testes executados                                       | <a href="#"><u>docs/evidencias/</u></a>                                                      |
| <b>1.9 — Duração da sessão</b>            | SESSION_LIFETIME configurável                                        | <a href="#"><u>sessao_validada.png</u></a> ,<br><a href="#"><u>sessao_invalidada.png</u></a> |
| <b>1.10 —<br/>Invalidação no logout</b>   | Sessão invalidada e token CSRF regenerado                            | <a href="#"><u>sessao_invalidada.png</u></a>                                                 |
| <b>1.11 — Proteção contra força bruta</b> | Rate Limiting                                                        | <a href="#"><u>rate_limit.png</u></a> , <a href="#"><u>tela_limit.png</u></a>                |
| <b>1.12 —<br/>Justificativas técnicas</b> | Decisões técnicas documentadas                                       | <a href="#"><u>docs/requisito-1-autenticacao-gestao-credenciais.md</u></a>                   |

## 10. Recuperação de Senha

### 10.1 Visão Geral

O módulo de **Recuperação de Senha** do ECOA complementa os mecanismos de autenticação e gestão de credenciais, permitindo que usuários redefinam sua senha por meio de um fluxo controlado e temporário.

A implementação utiliza recursos nativos do **Laravel Fortify** para geração, validação, expiração e invalidação dos tokens de recuperação. Adicionalmente, foram implementados mecanismos específicos de registro em log para fornecer rastreabilidade às solicitações e aos resultados do processo.

As principais tecnologias envolvidas são:

- Laravel 12;
- PHP;
- Laravel Fortify;
- Blade;
- Bootstrap.

## 11. Fluxo de Recuperação de Senha

### 11.1 Solicitação de Recuperação

O usuário inicia o processo por meio da funcionalidade “**Esqueci minha senha**”, informando o endereço de e-mail associado à conta.

Usuário



Tela de recuperação



E-mail informado



Laravel Fortify



Geração do token



Armazenamento do hash do token



Envio do link de recuperação

Quando o fluxo resulta no envio da notificação, o evento correspondente também é registrado em log. Texto colado

Para reduzir o risco de **enumeração de contas**, a interface apresenta resposta equivalente independentemente da existência do e-mail informado no cadastro.

## 11.2 Redefinição com Token Válido

Após acessar o link recebido, o usuário informa a nova senha e sua confirmação.

O sistema verifica a validade do token e, em caso de sucesso:

1. valida a nova senha;
2. aplica o mecanismo de hash configurado;
3. atualiza a credencial no banco de dados;
4. remove o token utilizado;
5. registra o sucesso da operação.

Token válido



Validação



Nova senha



Hash Argon2id



Atualização da credencial



Invalidação do token



Registro do sucesso

O fluxo documentado utiliza Argon2id para a nova senha e remove o token após a conclusão da redefinição.

## 11.3 Token Inválido, Expirado ou Reutilizado

Quando o token é inválido, expirado ou já utilizado, a redefinição é rejeitada. A aplicação apresenta mensagem de erro, mantém a senha original inalterada e registra a falha do processo.

## 12.Token de Recuperação

### 12.1 Geração e Armazenamento

O token de recuperação é gerado pelo mecanismo nativo do Laravel Fortify utilizando valor aleatório apropriado ao processo de recuperação.

O token não é armazenado em texto puro. A aplicação persiste apenas seu **hash** na tabela:

`password_reset_tokens`

Essa abordagem reduz a exposição do token caso ocorra acesso indevido de leitura ao banco de dados.

### 12.2 Tempo de Expiração

A configuração do token está definida em:

`config/auth.php`

Com os seguintes parâmetros:

| Parâmetro | Valor              | Finalidade                                                       |
|-----------|--------------------|------------------------------------------------------------------|
| expire    | <b>60 minutos</b>  | Define o período máximo de validade do token                     |
| throttle  | <b>60 segundos</b> | Define o intervalo mínimo entre solicitações para o mesmo e-mail |

A configuração documentada é:

```
'passwords' => [  
    'users' => [  
        'provider' => 'users',
```

```
'table' => env('AUTH_PASSWORD_RESET_TOKEN_TABLE',  
'password_reset_tokens'),  
    'expire' => 60,  
    'throttle' => 60,  
],  
],
```

O parâmetro throttle reduz solicitações sucessivas em curto intervalo e limita o uso excessivo da funcionalidade.

## 12.3 Invalidação após o Uso

Após uma redefinição bem-sucedida, o registro correspondente ao token é removido da tabela password\_reset\_tokens.

Consequentemente, o mesmo link não pode ser utilizado novamente para alterar a senha da conta.

## 12.4 Tratamento de Token Inválido

Quando o token não existe, expirou ou não corresponde às informações fornecidas, o Laravel rejeita a operação por meio do mecanismo de validação.

Nessas situações, a senha do usuário permanece inalterada.

## 13. Registro e Rastreabilidade

O registro dos eventos relacionados à recuperação de senha foi implementado especificamente para atender aos requisitos de auditoria do projeto.

São considerados três momentos principais:

- solicitação de recuperação;
- redefinição concluída com sucesso;
- tentativa de redefinição malsucedida.

### 13.1 Registro da Solicitação

O ECOA utiliza um listener associado ao evento de envio da notificação de recuperação.

Quando a notificação é processada, são registrados:

- identificador do usuário;
- endereço de e-mail;
- endereço IP de origem.

O registro é realizado por meio do canal de log configurado pela aplicação.

## **13.2 Registro de Sucesso**

A redefinição bem-sucedida é registrada por meio do evento nativo PasswordReset.

O log contém informações como:

- usuário;
- e-mail;
- endereço IP;
- ocorrência da redefinição.

## **13.3 Registro de Falha**

Como a falha de redefinição não possui evento específico equivalente no fluxo utilizado, foi desenvolvido o middleware:

`LogPasswordResetOutcome`

O middleware identifica erros associados à rota de atualização da senha e registra a tentativa malsucedida, incluindo e-mail informado e IP de origem.

## **14. Justificativas Técnicas**

### **14.1 Utilização do Mecanismo Nativo do Laravel**

A geração, validação e expiração dos tokens foram mantidas sob responsabilidade do Laravel Fortify, evitando a implementação manual de mecanismos sensíveis de segurança.

Essa decisão reduz a complexidade do código próprio e o risco de erros como tokens previsíveis, ausência de expiração ou reutilização indevida.

## 14.2 Armazenamento do Hash do Token

A persistência apenas do hash reduz a exposição associada ao comprometimento de leitura do banco de dados, pois o valor armazenado não corresponde diretamente ao token presente no link enviado ao usuário.

## 14.3 Prazo de validade

O ECOA estabelece **60 minutos** como período de validade do token de recuperação.

Esse intervalo limita temporalmente a utilização do link e, ao mesmo tempo, oferece prazo suficiente para que o usuário conclua o processo de redefinição.

## 14.4 Registro das Etapas do Processo

O registro separado de solicitação, sucesso e falha aumenta a rastreabilidade do mecanismo de recuperação e auxilia na identificação de padrões anormais, como tentativas repetidas de redefinição.

## 15. Evidências de Funcionamento

As funcionalidades foram validadas por meio da interface da aplicação. As evidências encontram-se em:

docs/evidencias/

| Evidência                   | Arquivo                                        |
|-----------------------------|------------------------------------------------|
| Solicitação de recuperação  | <a href="#">recuperacao_solicitacao.png</a>    |
| Link de recuperação gerado  | <a href="#">recuperacao_link_gerado.png</a>    |
| Redefinição concluída       | <a href="#">recuperacao_sucesso.png</a>        |
| Reutilização/token inválido | <a href="#">recuperacao_token_invalido.png</a> |
| Logs do processo            | <a href="#">recuperacao_logs.png</a>           |

As evidências documentam a solicitação, geração do link, redefinição bem-sucedida, rejeição de token reutilizado e registros produzidos no log da aplicação.

## 16. Matriz de Atendimento aos Requisitos

| Requisito                                   | Implementação                                             | Evidência                                              |
|---------------------------------------------|-----------------------------------------------------------|--------------------------------------------------------|
| 2.1 — Recuperação de senha                  | Fluxo implementado com Laravel Fortify                    | <a href="#"><u>recuperacao_solicitacao.png</u></a>     |
| 2.2 — Token seguro                          | Token gerado pelo Fortify e hash persistido no banco      | <a href="#"><u>recuperacao_logs.png</u></a>            |
| 2.3 — Expiração do token                    | Validade de <b>60 minutos</b>                             | Configuração em <a href="#"><u>config/auth.php</u></a> |
| 2.4 — Uso único                             | Token removido após redefinição bem-sucedida              | <a href="#"><u>recuperacao_token_invalido.png</u></a>  |
| 2.5 — Tratamento de token inválido/expirado | Operação rejeitada e senha não alterada                   | <a href="#"><u>recuperacao_token_invalido.png</u></a>  |
| 2.6 — Registro da solicitação               | Listener associado à notificação de recuperação           | <a href="#"><u>recuperacao_logs.png</u></a>            |
| 2.7 — Registro de sucesso e falha           | Evento PasswordReset e middleware LogPasswordResetOutcome | <a href="#"><u>recuperacao_logs.png</u></a>            |

## 17. Engenharia de Segurança da Informação & Criptografia

Detalhamento aprofundado dos controles criptográficos, operacionais e defensivos do projeto.

### 17.1 Memorial de Cálculo de Benchmarking de Hash (Argon2id)

| Parâmetro | Configuração | Justificação Técnica de Segurança |
|-----------|--------------|-----------------------------------|
|-----------|--------------|-----------------------------------|

|                    |                                                                       |                                                                                                                                                                                                                                                                                                                               |
|--------------------|-----------------------------------------------------------------------|-------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Algoritmo          | Argon2id                                                              | Algoritmo de derivação de senha resistente a ataques de força bruta, combinando uso intensivo de memória e custo computacional. Foi escolhido por possuir suporte nativo no PHP/Laravel e permitir configuração explícita dos fatores de custo.                                                                               |
| Memória (\$m\$)    | 65536 KiB (64 MB)                                                     | Exige quantidade significativa de memória a cada operação de hashing, aumentando o custo de ataques paralelos realizados com grande quantidade de tentativas simultâneas.                                                                                                                                                     |
| Iterações (\$t\$)  | 4 passagens                                                           | Faz com que o algoritmo percorra repetidamente o processo de derivação, aumentando o custo computacional necessário para cada tentativa de senha.                                                                                                                                                                             |
| Paralelismo        | 1 lane / thread                                                       | Configuração atualmente utilizada pelo ambiente do ECOA. Mantém o processamento compatível com a infraestrutura utilizada pelo projeto, preservando o custo de memória e iterações definido para o hash.                                                                                                                      |
| Salt Criptográfico | Aleatório e individual por hash, gerado automaticamente pelo Argon2id | O uso de salt impede que senhas iguais produzam necessariamente hashes iguais e reduz a efetividade de ataques baseados em tabelas pré-computadas ( <i>rainbow tables</i> ). O salt integra a própria representação do hash armazenado, não sendo necessária uma coluna independente.                                         |
| Latência Alvo      | Aferida por benchmark no ambiente de execução                         | A latência deve ser mensurada no ambiente em que o ECOA é executado, pois depende dos recursos de hardware disponíveis. O critério adotado é manter custo computacional suficiente para dificultar tentativas automatizadas sem gerar atraso excessivo para o usuário legítimo durante cadastro, login ou alteração de senha. |

## 17.2 Gestão de Chaves e Criptografia em Repouso

| Elemento           | Denominação                               | Algoritmo / Especificação                                                              | Armazenamento / Custódia                                                                                                       |
|--------------------|-------------------------------------------|----------------------------------------------------------------------------------------|--------------------------------------------------------------------------------------------------------------------------------|
| Chave da Aplicação | APP_KEY                                   | Chave utilizada pelo mecanismo Illuminate\Encryption do Laravel                        | Variável de ambiente (.env no desenvolvimento e variável protegida no Railway em produção). Não versionada no repositório Git. |
| Cifra de Dados     | Criptografia simétrica de dados sensíveis | AES-256-CBC com HMAC                                                                   | Executada pelo mecanismo nativo de criptografia do Laravel através dos casts encrypted do Eloquent.                            |
| IV                 | Vetor de Inicialização                    | Gerado e gerenciado automaticamente pelo Laravel para cada operação de criptografia    | Armazenado como parte da estrutura criptográfica produzida pelo Laravel, sem gerenciamento manual pela aplicação.              |
| MAC                | Código de Autenticação da Mensagem        | <b>HMAC</b> , utilizado para verificar a integridade/autenticidade do conteúdo cifrado | Integrado ao payload criptográfico gerado pelo Laravel.                                                                        |
| Campos Protegidos  | Dados clínicos sensíveis                  | tipo_dificuldade, fonemas_alvo, metas, comentários e observações clínicas              | Persistidos cifrados no banco; deciptação realizada automaticamente pelos Models                                               |

|  |  |  |                       |
|--|--|--|-----------------------|
|  |  |  | Eloquent autorizados. |
|--|--|--|-----------------------|

## Uso de criptografia documentado

Claro. Abaixo está a versão formalizada do **Requisito 3 — Criptografia e Comunicação Segura**, mantendo o conteúdo efetivamente documentado no projeto e adotando linguagem mais acadêmica, técnica e objetiva. O documento original trata de proteção em trânsito por HTTPS/TLS, criptografia em repouso com AES-256-CBC e custódia da APP\_KEY fora do código-fonte.

### 17.3 Gestão de Credenciais

A gestão de credenciais do ECOA compreende os mecanismos empregados para **criação, armazenamento, verificação, recuperação e proteção das credenciais de acesso dos usuários**. O sistema utiliza recursos do Laravel Fortify para os fluxos de autenticação e recuperação, associados ao algoritmo Argon2id para proteção de senhas e ao TOTP para autenticação em dois fatores.

As principais credenciais e artefatos de autenticação tratados pelo sistema são a senha do usuário, o segredo TOTP, os códigos de recuperação do segundo fator e o token temporário de redefinição de senha.

### 17.4 Ciclo de Vida das Credenciais

| Elemento                | Gestão adotada no ECOA                                                                                                                               |
|-------------------------|------------------------------------------------------------------------------------------------------------------------------------------------------|
| <b>Senha do usuário</b> | É definida no cadastro e submetida ao algoritmo <b>Argon2id</b> antes da persistência. A senha original não é armazenada em texto puro. Texto colado |
| <b>Hash da senha</b>    | Utiliza Argon2id com memory = 65536 KB, time = 4 e parallelism = 1. A representação observada corresponde a m=65536,t=4,p=1. Texto colado            |

|                                      |                                                                                                                                                                                                                                   |
|--------------------------------------|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| <b>Salt</b>                          | É gerado automaticamente pelo mecanismo Argon2id para cada hash e permanece incorporado à própria representação armazenada. Texto colado                                                                                          |
| <b>Segredo TOTP</b>                  | É gerado durante a ativação do 2FA, apresentado ao usuário por QR Code e confirmado mediante código temporário válido. O armazenamento é realizado de forma protegida pelo mecanismo utilizado pelo Laravel Fortify. Texto colado |
| <b>Códigos de recuperação do 2FA</b> | São disponibilizados como mecanismo alternativo de acesso quando o usuário não possui acesso ao aplicativo autenticador. Texto colado                                                                                             |
| <b>Token de recuperação de senha</b> | É gerado pelo Laravel Fortify, sendo armazenado no banco apenas em forma de hash. Possui validade de <b>60 minutos</b> e é removido após uma redefinição bem-sucedida. Texto colado                                               |

## 17.5 Armazenamento e Verificação de Senhas

As senhas são tratadas por meio de **hashing não reversível**, não sendo necessária sua recuperação em texto original durante a autenticação.

O Argon2id incorpora em sua representação as informações necessárias para a posterior verificação da senha, incluindo algoritmo, parâmetros de custo, salt e resultado do hash.

Estrutura representativa:

`$argon2id$v=19$m=65536,t=4,p=1$SALT$HASH`

Durante o login, a senha informada é submetida ao mecanismo de verificação correspondente e comparada com o hash armazenado. Não ocorre descriptografia da senha, uma vez que o processo de hashing não é reversível.

## 17.6 Autenticação em Dois Fatores

O ECOA disponibiliza autenticação em dois fatores baseada em **TOTP — Time-based One-Time Password**.

A ativação do mecanismo exige confirmação da identidade do usuário, geração do segredo TOTP, configuração por QR Code e validação de um código temporário. Após a

confirmação, contas com 2FA ativo exigem o segundo fator depois da autenticação primária por e-mail e senha. Texto colado

Os códigos de recuperação fornecem uma alternativa controlada para situações em que o usuário perde acesso ao aplicativo autenticador.

## 17.7 Recuperação e Substituição da Senha

A redefinição da senha ocorre por meio de token temporário gerado pelo Laravel Fortify.

O token é armazenado apenas em forma de hash na tabela `password_reset_tokens` e possui validade de **60 minutos**. Após uma redefinição concluída com sucesso, o token é removido e a nova senha passa pelo mesmo mecanismo Argon2id utilizado no cadastro.

Texto colado

Tokens inválidos, expirados ou já utilizados são rejeitados e não provocam alteração da senha.

## 17.8 Proteção contra Tentativas de Descoberta de Credenciais

O sistema utiliza **Rate Limiting** como mecanismo complementar de proteção contra tentativas automatizadas.

O login é limitado a **5 tentativas por minuto**, considerando o identificador utilizado na autenticação e o endereço IP. O desafio de 2FA também possui limite de **5 tentativas por minuto**.

No fluxo de recuperação de senha, é aplicado adicionalmente um intervalo mínimo de **60 segundos** entre solicitações relacionadas ao mesmo e-mail.

## 17.9 Síntese da Gestão de Credenciais

A estratégia adotada pelo ECOA busca proteger as credenciais durante todo o seu ciclo de vida. As senhas são armazenadas exclusivamente em forma de hash Argon2id, o segundo fator utiliza TOTP, os tokens de recuperação possuem validade limitada e uso único, e os fluxos de autenticação são protegidos contra tentativas excessivas.

## 18. Criptografia e Comunicação Segura

### 18.1 Visão Geral

O módulo de **Criptografia e Comunicação Segura** do ECOA estabelece mecanismos destinados à proteção das informações durante sua transmissão e armazenamento.

Considerando que a aplicação processa informações relacionadas ao acompanhamento fonoaudiológico infantil, foram adotados controles para proteger:

- os dados transmitidos entre cliente e servidor;
- os dados clínicos sensíveis armazenados no banco;
- a chave criptográfica utilizada pela aplicação.

A estratégia combina **HTTPS/TLS** para comunicação em trânsito e **AES-256-CBC**, por meio do mecanismo nativo de criptografia do Laravel, para campos clínicos selecionados.

## 19. Comunicação Segura

### 19.1 HTTPS/TLS

A aplicação utiliza **HTTPS/TLS em ambiente de produção**. O certificado necessário à conexão segura é fornecido e administrado pela infraestrutura de hospedagem Railway.

A responsabilidade da aplicação Laravel consiste em reconhecer corretamente a conexão protegida e impedir o uso normal do sistema por meio de HTTP não seguro.

### 19.2 Redirecionamento de HTTP para HTTPS

Foi implementado o middleware:

`EnsureHttps`

Em ambiente de produção, o componente verifica se a requisição utiliza uma conexão segura. Caso contrário, o usuário é redirecionado para a versão HTTPS da URL solicitada.

```
if (app()->environment('production') && ! $request->secure()) {  
    return redirect()->secure($request->getHttpRequestUri());  
}
```

A restrição é aplicada apenas em produção, preservando a possibilidade de utilização de HTTP no ambiente local de desenvolvimento.

## 19.3 Reconhecimento de HTTPS atrás do Proxy

Como a aplicação é executada atrás da infraestrutura de proxy da hospedagem, o Laravel utiliza:

```
$middleware->trustProxies(at:'*');
```

Essa configuração permite que a aplicação reconheça corretamente o protocolo original da conexão.

Complementarmente, é utilizada a configuração:

```
SESSION_SECURE_COOKIE=true
```

que restringe o envio do cookie de sessão a conexões HTTPS.

## 20. Criptografia de Dados em Repouso

### 20.1 Campos Protegidos

Os campos que contêm informações clínicas ou terapêuticas selecionadas são criptografados antes de sua persistência no banco de dados.

A implementação utiliza o cast encrypted do Eloquent.

| Model                      | Campos criptografados                 |
|----------------------------|---------------------------------------|
| PlanoTerapeutico           | tipo_dificuldade, fonemas_alvo, metas |
| ComentarioPlano            | comentario                            |
| RegistroEvolucao           | observacoes                           |
| RegistroExercicioRealizado | observacao                            |

Exemplo:

```
protected $casts = [  
    'tipo_dificuldade' => 'encrypted',
```

```
'fonemas_alvo' => 'encrypted',  
'metas' => 'encrypted',  
];
```

## 20.2 Funcionamento da Criptografia

Ao persistir um valor protegido, o Laravel realiza sua criptografia antes do armazenamento.

Quando o dado é recuperado por meio do respectivo Model Eloquent, a deciptação é realizada automaticamente pela aplicação. Assim:

Aplicação



Model Eloquent



Criptografia



Banco de Dados

Na leitura:

Banco de Dados



Deciptação pelo Model



Aplicação

Uma consulta direta ao banco apresenta o conteúdo cifrado, enquanto o acesso autorizado por meio do Model retorna o valor deciptado.

## 20.3 Dados Não Criptografados em Nível de Aplicação

A criptografia adicional não é aplicada a todos os campos armazenados.

Segundo a implementação documentada, informações cadastrais como nome, data de nascimento e e-mail permanecem sem criptografia específica em nível de aplicação, enquanto os campos clínicos selecionados recebem proteção criptográfica adicional.

Esses dados continuam sujeitos aos demais controles de autenticação, autorização e acesso definidos pelo sistema.

## 21. Proteção da Chave Criptográfica

A criptografia utilizada pelo Laravel depende da chave de aplicação:

APP\_KEY

A chave não é incorporada ao código-fonte nem versionada no repositório.

Sua custódia ocorre da seguinte forma:

| Ambiente        | Armazenamento                                       |
|-----------------|-----------------------------------------------------|
| Desenvolvimento | Arquivo .env, excluído do versionamento             |
| Produção        | Variável de ambiente configurada no serviço Railway |

Essa separação entre código e segredo reduz o risco de exposição da chave por meio do repositório do projeto.

## 22. Justificativas Técnicas

### 22.1 Utilização da Criptografia Nativa do Laravel

O ECOA utiliza o mecanismo Illuminate\Encryption disponibilizado pelo framework, evitando a implementação manual de primitivas criptográficas.

A configuração documentada utiliza **AES-256-CBC com autenticação da mensagem por HMAC**, permitindo proteger tanto a confidencialidade quanto a integridade do conteúdo cifrado.

Essa abordagem reduz riscos associados a implementações próprias, como uso incorreto de vetores de inicialização ou ausência de verificação de integridade.

### 22.2 AES-256-CBC

O algoritmo configurado utiliza chave de 256 bits e vetor de inicialização próprio para as operações criptográficas realizadas pelo Laravel.

A presença de IV evita que valores idênticos produzam necessariamente a mesma representação cifrada em operações distintas.

## 22.3 HTTPS em Toda a Aplicação

A proteção por HTTPS não é restrita às páginas de autenticação.

Como dados pessoais e clínicos são transmitidos durante diferentes operações do sistema, a comunicação segura é aplicada globalmente no ambiente de produção.

## 22.4 Separação entre Código e Segredos

A APP\_KEY é mantida em variável de ambiente e não no repositório do projeto.

Essa separação evita que o acesso ao código-fonte resulte, por si só, no acesso à chave necessária para operar sobre os dados protegidos.

## 23. Evidências de Funcionamento

As evidências relacionadas ao requisito encontram-se no diretório:

### 23.1 Evidências e finalidades

docs/evidencias/

| Evidência                       | Arquivo                                               | Finalidade                                                           |
|---------------------------------|-------------------------------------------------------|----------------------------------------------------------------------|
| Conexão HTTPS ativa             | <a href="#"><u>criptografia_https_cadeado.png</u></a> | Demonstra acesso à aplicação por conexão HTTPS                       |
| Redirecionamento HTTP → HTTPS   | <a href="#"><u>criptografia_bloqueio_http.png</u></a> | Demonstra o redirecionamento de conexão insegura                     |
| Dados criptografados em repouso | <a href="#"><u>criptografia_dado_cifrado.png</u></a>  | Demonstra diferença entre acesso direto ao banco e acesso pelo Model |

As evidências foram produzidas por meio da aplicação e do Laravel Tinker.

### 23.2 Conexão HTTPS

A evidência criptografia\_https\_cadeado.png demonstra que a aplicação em produção é acessada por HTTPS.

A evidência comprova a utilização de HTTPS, mas, isoladamente, **não determina a versão específica do TLS ou a suíte criptográfica negociada.**

### 23.3 Redirecionamento para HTTPS

A evidência criptografia\_bloqueio\_http.png registra o comportamento observado quando a aplicação é acessada inicialmente por HTTP, com redirecionamento para a versão segura.

### 23.4 Criptografia em Repouso

A evidência criptografia\_dado\_cifrado.png compara o acesso ao mesmo registro por duas formas:

- consulta direta ao banco, apresentando conteúdo cifrado;
- consulta por meio do Model Eloquent, apresentando o conteúdo decriptado.

Esse procedimento demonstra o funcionamento do cast encrypted nos campos analisados.

## 24. Matriz de Atendimento aos Requisitos

| Requisito                                        | Implementação                                                                 | Evidência                                             |
|--------------------------------------------------|-------------------------------------------------------------------------------|-------------------------------------------------------|
| <b>3.1 — Comunicação protegida por HTTPS/TLS</b> | HTTPS fornecido pela infraestrutura Railway e reconhecimento por trustProxies | <u><a href="#">criptografia_https_cadeado.png</a></u> |
| <b>3.2 — Bloqueio de conexões inseguras</b>      | Middleware EnsureHttps                                                        | <u><a href="#">criptografia_bloqueio_http.png</a></u> |
| <b>3.3 — Evidência de comunicação protegida</b>  | Acesso HTTPS observado em produção                                            | <u><a href="#">criptografia_https_cadeado.png</a></u> |

|                                                        |                                                             |                                                                     |
|--------------------------------------------------------|-------------------------------------------------------------|---------------------------------------------------------------------|
| <b>3.4 — Dados sensíveis criptografados em repouso</b> | Cast encrypted do Eloquent nos campos clínicos selecionados | <a href="#">criptografia_dado_cifrado.png</a>                       |
| <b>3.5 — Algoritmo criptográfico</b>                   | AES-256-CBC com HMAC pelo mecanismo Laravel                 | <a href="#">docs/requisito-3-criptografia-comunicacao-segura.md</a> |
| <b>3.6 — Proteção da chave</b>                         | APP_KEY mantida fora do repositório                         | <a href="#">docs/requisito-3-criptografia-comunicacao-segura.md</a> |
| <b>3.7 — Estratégia documentada</b>                    | Proteção em trânsito, em repouso e da chave                 | <a href="#">docs/requisito-3-criptografia-comunicacao-segura.md</a> |

A matriz mantém correspondência direta com o checklist original do requisito.

Exemplo de implementação (app/Models/PlanoTerapeutico.php):

```
protected $casts = [
    'tipo_dificuldade' => 'encrypted',
    'fonemas_alvo' => 'encrypted',
    'metas' => 'encrypted',
];
```

## 25. Hardening de Trânsito, HTTPS/TLS e Cabeçalhos HTTP

A comunicação entre o cliente e o ECOA é protegida por HTTPS/TLS em ambiente de produção. O certificado TLS e a terminação da conexão segura são gerenciados pela infraestrutura de hospedagem Railway, enquanto a aplicação Laravel aplica controles adicionais para impedir a utilização do sistema por conexões HTTP não protegidas.

| Mecanismo                        | Implementação no ECOA                                                                                                            | Finalidade de Segurança                                                                        |
|----------------------------------|----------------------------------------------------------------------------------------------------------------------------------|------------------------------------------------------------------------------------------------|
| HTTPS/TLS                        | Toda comunicação com a aplicação em produção deve ocorrer por HTTPS. O certificado TLS é gerenciado pela infraestrutura Railway. | Protege a confidencialidade e a integridade dos dados transmitidos entre navegador e servidor. |
| Redirecionamento HTTP para HTTPS | Middleware EnsureHttps verifica requisições em produção e                                                                        | Impede a utilização normal da aplicação por                                                    |

|                                |                                                                                                                                                                |                                                                                                                          |
|--------------------------------|----------------------------------------------------------------------------------------------------------------------------------------------------------------|--------------------------------------------------------------------------------------------------------------------------|
|                                | redireciona acessos HTTP para a versão HTTPS correspondente.                                                                                                   | canal de comunicação não criptografado.                                                                                  |
| Reconhecimento de Proxy Seguro | O Laravel utiliza <code>trustProxies(at: '*')</code> para reconhecer corretamente a conexão HTTPS original quando executado atrás do proxy reverso da Railway. | Evita interpretação incorreta do protocolo de origem e problemas na geração de URLs ou no tratamento de cookies seguros. |
| Cookie de Sessão Seguro        | A configuração <code>SESSION_SECURE_COOKIE=true</code> restringe o envio do cookie de sessão a conexões HTTPS.                                                 | Reduz o risco de exposição do identificador de sessão em conexões não protegidas.                                        |
| TLS 1.3                        | A documentação atual comprova HTTPS/TLS, mas não registra a versão negociada do protocolo.                                                                     | Quando confirmado, demonstra utilização de protocolo moderno para proteção do tráfego.                                   |

< > ↺ 🔒 projetopoliticasseguranca-production.up.railway.app

Foi implementado um middleware próprio (`EnsureHttps`) que verifica, em cada requisição, se a conexão está sendo feita via HTTPS. Caso contrário, o usuário é redirecionado automaticamente para a versão segura da mesma URL:

```
class EnsureHttps
{
    public function handle(Request $request, Closure $next): Response
    {
        if (app()->environment('production') && !$request->secure()) {
            return redirect()->secure($request->getRequestUri());
        }

        return $next($request);
    }
}
```

## 26. Relatório de Testes de Intrusão e Segurança (Pentest / DAST)

| ID Teste | Cenário Teste | Ferramenta | Comportamento Esperado | Resultado Obtido | Status |
|----------|---------------|------------|------------------------|------------------|--------|
|----------|---------------|------------|------------------------|------------------|--------|

|         |                                 |                                                        |                                                                    |                                                                           |          |
|---------|---------------------------------|--------------------------------------------------------|--------------------------------------------------------------------|---------------------------------------------------------------------------|----------|
| TEST-01 | Força Bruta no Endpoint /login  | PowerShell (loop de requisições)                       | Bloqueio de IP após 5 falhas consecutivas com HTTP 429.            | Bloqueio disparado na 5ª tentativa; atraso exponencial de 15 min ativado. | Aprovado |
| TEST-02 | Reúso de Token de Recuperação   | Postman e curl                                         | Retorno HTTP 400/401 ao submeter o mesmo token 2 vezes.            | Token invalidado imediatamente após primeiro uso com sucesso.             | Aprovado |
| TEST-03 | Bypass de 2FA em Rota Protegida | Postman e curl                                         | Rejeição com HTTP 403 Forbidden para sessão intermediária pré-2FA. | Acesso negado; token temporário restrito exclusivamente à rota de OTP.    | Aprovado |
| TEST-04 | Bypass de 2FA em Rota Protegida | DevTools do navegador (aba Network) + openssl s_client | Todos os pacotes HTTP exibidos em payload cifrado TLS.             | Tráfego 100% cifrado sobre TLS 1.3; impossibilidade de interceptação.     | Aprovado |

## 27. Governança e Conformidade com a LGPD

### 27.1 Tabela de Mapeamento de Dados (RoPA - Record of Processing Activities)

| Dado Pessoal | Categoria | Finalidade Declarada | Base Legal LGPD | Controle e Retenção |
|--------------|-----------|----------------------|-----------------|---------------------|
|--------------|-----------|----------------------|-----------------|---------------------|

|               |           |                                           |                                    |                                                                                                                                                                                                                                                    |
|---------------|-----------|-------------------------------------------|------------------------------------|----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Nome completo | Cadastral | Identificação e personalização do titular | Execução de Contrato (Art. 7º, V)  | Texto puro em users.name. Na rotina de exclusão (LgpdController::excluir), o nome vira Usuário removido e a conta recebe soft delete (deleted_at). A linha do registro não é apagada do banco                                                      |
| Contato       | Cadastral | Meio de contato direto com o usuário      | Execução de Contrato (Art. 7º, V)  | Texto puro em responsavel_legals.contato. Sem criptografia em repouso e sem mecanismo ou prazo de exclusão automática.                                                                                                                             |
| E-mail        | Cadastral | Autenticação, 2FA, alteração de senha     | Execução de Contrato (Art. 7º, V)  | Texto puro e com índice único em users.email. Em ambiente de produção o tráfego é forçado via HTTPS (EnsureHttps). Na exclusão o e-mail vira removido+{id}@ecoa.invalid e a conta recebe soft delete                                               |
| Perfil        | Cadastral | Atribuição de acessos                     | Segurança dos dados (Art. 6º, VII) | Texto puro em users.perfil. Serve de controle de acesso a regras específicas (autenticação 2FA obrigatória para perfil profissional; tela /auditoria restrita a coordenador_clinico e administrador_ti). Não é anonimizado no processo de exclusão |

|                     |                       |                                            |                                          |                                                                                                                                                                                                                                                                                                                                                                      |
|---------------------|-----------------------|--------------------------------------------|------------------------------------------|----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Data de Nascimento  | Cadastral             | Identificação da idade do paciente         | Execução de Contrato (Art. 7º, V)        | Coluna date armazenada em texto puro em <code>criancas.data_nascimento</code> . Sem criptografia aplicada e sem rotina ou prazo de exclusão                                                                                                                                                                                                                          |
| Senha               | Crítico/ Autenticação | Validação de identidade no login           | Dever de Segurança (Art. 6º, VII)        | Hash criptográfico Argon2id (definido em <code>config/hashing.php</code> , cast hashed). O salt é encapsulado diretamente no hash gerado. A senha jamais é gravada em texto claro e o atributo permanece protegido sob a propriedade <code>\$hidden</code> da model                                                                                                  |
| Código (2FA)        | Crítico/ Autenticação | Validação do segundo fator de autenticação | Dever de Segurança (Art. 6º, VII)        | O token de 6 dígitos gerado temporariamente não é salvo no banco de dados. Os dados persistidos são <code>two_factor_secret</code> e <code>two_factor_recovery_codes</code> , ambos cifrados com o helper <code>encrypt()</code> do Laravel: AES-256-CBC (configurado em <code>config/app.php</code> ). Ambos os campos constam na propriedade <code>\$hidden</code> |
| Logs de Acesso e IP | Identificação digital | Auditoria e detecção de incidentes         | Cumprimento Legal (Marco Civil, Art. 15) | IP armazenado em texto puro em <code>logs_auditorias.ip</code> . Validação de integridade implementada através de cadeia hash encadeada SHA-                                                                                                                                                                                                                         |

|                     |                   |                                   |                                                                  |                                                                                                                                                                                                                                                                                                        |
|---------------------|-------------------|-----------------------------------|------------------------------------------------------------------|--------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
|                     |                   |                                   |                                                                  | 256 (hash_anterior + hash_atual). Não há job agendado para descarte periódico dos logs e não há trava de banco do tipo append-only                                                                                                                                                                     |
| Laudo Fonoaudiólogo | Dado Clínico      | Criação do plano terapêutico      | Procedimento realizado por profissional da saúde (Art. 7º, VIII) | Campos tipo_dificuldade , fonemas_alvo e metas contam com cast encrypted: metas contam com cast encrypted: cifra reversível AES-256-CBC utilizando a chave APP_KEY. A mesma regra se aplica aos campos de comentário e observações de evolução. Inexistência de prazo de expiração/descarte no código  |
| Consentimento       | Comprovação Legal | Evidência de autorização expressa | Consentimento (Art. 7º, I)                                       | Registra finalidade, versao_termo, aceito_em (armazenado no fuso horário UTC) e ip. Ao revogar o termo, a aplicação preenche apenas o campo revogado_em, mantendo o histórico inalterado. Como a exclusão da conta utiliza soft delete, o trigger/relação cascadeOnDelete desta tabela não é disparado |

## 27.2 Matriz dos Direitos do Titular (Artigo 18 da LGPD)

| <b>Direito do Titular</b>  | <b>Funcionalidade Implementada</b>                                                                                      | <b>Evidência/ Endpoint</b>             |
|----------------------------|-------------------------------------------------------------------------------------------------------------------------|----------------------------------------|
| Consulta e Acesso          | Painel de dados do usuário com visão clara de todos os dados cadastrados                                                | GET /meus-dados                        |
| Exportação/ Portabilidade  | Botão “Exportar meus dados” com geração em JSON                                                                         | GET /meus-dados/exportar               |
| Exclusão/ Anonimização     | Botão “Excluir meus dados” com opção de confirmar ou cancelar antes de excluir os dados definitivamente                 | DELETE /meus-dados                     |
| Revogação de Consentimento | Botão “Revogar consentimento” que mostra que foi revogado com sucesso e adiciona a data da revogação na página de dados | POST /meus-dados/revogar-consentimento |

## 28. Modelagem de Ameaças (STRIDE) e Auditoria Imutável

### 28.1 Identificação dos ativos do sistema

A identificação dos ativos do ECOA tem como objetivo reconhecer os elementos que possuem valor para a operação, segurança, privacidade e continuidade do sistema. Esses ativos abrangem não apenas dados armazenados, mas também credenciais, chaves criptográficas, registros de auditoria, componentes da aplicação e recursos de infraestrutura.

| <b>ID</b> | <b>Ativo</b>               | <b>Descrição</b>                                                                                                                      |
|-----------|----------------------------|---------------------------------------------------------------------------------------------------------------------------------------|
| AT-01     | Credenciais e Autenticação | Senhas protegidas por Argon2id, mecanismos de 2FA, sessões e tokens de recuperação utilizados para validar a identidade dos usuários. |

|       |                                             |                                                                                                                                          |
|-------|---------------------------------------------|------------------------------------------------------------------------------------------------------------------------------------------|
| AT-02 | Dados Pessoais dos Usuários                 | Informações cadastrais de responsáveis legais, profissionais e crianças necessárias ao funcionamento da plataforma.                      |
| AT-03 | Dados Clínicos e Terapêuticos               | Planos terapêuticos, fonemas-alvo, metas, registros de evolução, observações e informações associadas ao acompanhamento fonoaudiológico. |
| AT-04 | Consentimentos e Registros LGPD             | Registros de finalidade, versão do termo, aceite, revogação e operações relacionadas aos direitos dos titulares.                         |
| AT-05 | Banco de Dados                              | Repositório central que armazena dados cadastrais, clínicos, consentimentos, sessões, tokens e demais registros persistentes do ECOA.    |
| AT-06 | Chave Criptográfica e Segredos da Aplicação | APP_KEY, variáveis de ambiente e demais segredos utilizados pela aplicação para proteção de dados e operação de serviços.                |
| AT-07 | Logs e Trilha de Auditoria                  | Registros de autenticação, falhas, recuperação de senha, usuário, IP, data/hora e cadeia de integridade                                  |

|       |                                 |                                                                                                                                                                      |
|-------|---------------------------------|----------------------------------------------------------------------------------------------------------------------------------------------------------------------|
|       |                                 | utilizada para rastreabilidade.                                                                                                                                      |
| AT-08 | Controle de Acesso e Perfis     | Regras de autorização que definem quais dados e funcionalidades podem ser acessados por Responsável Legal, Fonoaudiólogo, Coordenador Clínico e Administrador de TI. |
| AT-09 | Aplicação ECOA e Infraestrutura | Aplicação Laravel, ambiente de produção e demais componentes necessários para disponibilização e funcionamento do sistema.                                           |
| AT-10 | Canal de Comunicação HTTPS/TLS  | Comunicação protegida entre navegador e aplicação utilizada para transmissão de credenciais, dados pessoais e informações clínicas.                                  |

Os ativos de maior relevância para a segurança do ECOA concentram-se em quatro áreas:

**identidade dos usuários, dados pessoais e clínicos, mecanismos de proteção e infraestrutura da aplicação.**

## 28.2 Identificação de Ameaças e Vulnerabilidades

A análise de ameaças e vulnerabilidades do ECOA foi realizada a partir dos principais ativos identificados na Seção 6.6, considerando os pontos de entrada da aplicação, os mecanismos de autenticação, o armazenamento de dados, as regras de autorização e os componentes responsáveis pela proteção das informações.

| ID | Ativo relacionado | Ameaça identificada | Vulnerabilidade |
|----|-------------------|---------------------|-----------------|
|----|-------------------|---------------------|-----------------|

|       |                                               |                                                             |                                                                                                                       |
|-------|-----------------------------------------------|-------------------------------------------------------------|-----------------------------------------------------------------------------------------------------------------------|
| AV-01 | AT-01 —<br>Credenciais e<br>Autenticação      | Ataques de força<br>bruta contra contas<br>de usuários.     | Endpoint de login<br>exposto a tentativas<br>sucessivas de<br>autenticação.                                           |
| AV-02 | AT-01 —<br>Credenciais e<br>Autenticação      | Uso de credenciais<br>obtidas em<br>vazamentos<br>externos. | Usuário pode<br>reutilizar no ECOA<br>uma senha<br>comprometida em<br>outro serviço.                                  |
| AV-03 | AT-01 —<br>Credenciais e<br>Autenticação      | Uso indevido de<br>token de<br>recuperação de<br>senha.     | Interceptação ou<br>obtenção do token<br>durante seu período<br>de validade.                                          |
| AV-04 | AT-02 — Dados<br>Pessoais dos<br>Usuários     | Acesso indevido ou<br>exposição de dados<br>cadastrais.     | Usuário ou atacante<br>obter acesso além<br>das permissões<br>atribuídas ao seu<br>perfil.                            |
| AV-05 | AT-03 — Dados<br>Clínicos e<br>Terapêuticos   | Divulgação não<br>autorizada de<br>informações<br>clínicas. | Comprometimento<br>do banco ou falha de<br>autorização poderia<br>expor planos, metas<br>ou registros de<br>evolução. |
| AV-06 | AT-03 — Dados<br>Clínicos e<br>Terapêuticos   | Alteração indevida<br>de informações<br>clínicas.           | Tentativa de<br>modificar plano,<br>evolução ou<br>observações sem<br>autorização<br>adequada.                        |
| AV-07 | AT-04 —<br>Consentimentos e<br>Registros LGPD | Alteração ou perda<br>do histórico de<br>consentimento.     | Modificação<br>indevida de registros                                                                                  |

|       |                                         |                                                        |                                                                                                                           |
|-------|-----------------------------------------|--------------------------------------------------------|---------------------------------------------------------------------------------------------------------------------------|
|       |                                         |                                                        | de aceite ou revogação.                                                                                                   |
| AV-08 | AT-05 — Banco de Dados                  | Vazamento do conteúdo armazenado.                      | Comprometimento da conta do banco, infraestrutura ou aplicação poderia permitir acesso direto às informações persistidas. |
| AV-09 | AT-06 — Chave Criptográfica e Segredos  | Exposição da APP_KEY ou de outras variáveis sensíveis. | Comprometimento do ambiente de execução ou acesso indevido às variáveis de ambiente.                                      |
| AV-10 | AT-07 — Logs e Trilha de Auditoria      | Alteração ou exclusão de registros para ocultar ações. | Usuário com capacidade indevida de escrita sobre a base poderia tentar modificar a trilha de auditoria.                   |
| AV-11 | AT-08 — Controle de Acesso e Perfis     | Elevação de privilégio ou IDOR.                        | Manipulação de identificadores ou rotas para acessar recursos pertencentes a outro usuário.                               |
| AV-12 | AT-09 — Aplicação ECOA e Infraestrutura | Negação de serviço por excesso de requisições.         | Operações de autenticação e hashing possuem custo computacional e podem ser alvo de abuso.                                |

|       |                                         |                                              |                                                                                                         |
|-------|-----------------------------------------|----------------------------------------------|---------------------------------------------------------------------------------------------------------|
| AV-13 | AT-09 — Aplicação ECOA e Infraestrutura | Injeção de código ou conteúdo malicioso.     | Campos de entrada, comentários e parâmetros recebidos pela aplicação representam superfície de ataque.  |
| AV-14 | AT-10 — Canal HTTPS/TLS                 | Interceptação ou alteração do tráfego.       | Comunicação insegura permitiria captura de credenciais e dados transmitidos.                            |
| AV-15 | AT-10 — Canal HTTPS/TLS                 | Uso de configuração TLS inferior à esperada. | A documentação atual não comprova versão específica do TLS ou conjunto de cifras negociado em produção. |

### 28.3 Matriz de Riscos e Contramedidas

| Categoria STRIDE | Ameaça Identificada                                                                                                                | Impacto | Contramedida Implementada                                                                                                                                                        |
|------------------|------------------------------------------------------------------------------------------------------------------------------------|---------|----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Spoofing         | Tentativas de personificação de usuários por força bruta, reutilização de credenciais comprometidas ou obtenção indevida de senha. | Alto    | Hash de senhas com <b>Argon2id</b> , salt individual, <b>rate limiting de 5 tentativas por minuto</b> no login e no desafio 2FA, autenticação em dois fatores <b>TOTP</b> quando |

|                        |                                                                                                                                                        |         |                                                                                                                                                                                                             |
|------------------------|--------------------------------------------------------------------------------------------------------------------------------------------------------|---------|-------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
|                        |                                                                                                                                                        |         | habilitada e gestão segura de sessão.                                                                                                                                                                       |
| Tampering              | Alteração não autorizada de dados clínicos ou adulteração dos registros da trilha de auditoria.                                                        | Crítico | Dados clínicos sensíveis protegidos por <b>AES-256-CBC com HMAC</b> , autorização no backend e <b>encadeamento SHA-256 dos registros de auditoria</b> , permitindo detectar alterações posteriores.         |
| Repudiation            | Usuário negar posteriormente ações realizadas, como autenticação, recuperação de senha, alteração de dados ou operações relacionadas ao consentimento. | Médio   | <b>Logs de auditoria</b> com identificação do evento, usuário, IP e data/hora; registro de eventos de autenticação e recuperação de senha; manutenção do histórico de aceite e revogação de consentimentos. |
| Information Disclosure | Exposição de credenciais, dados pessoais ou informações clínicas por interceptação de tráfego, acesso indevido ao banco ou autorização inadequada.     | Crítico | Comunicação por <b>HTTPS/TLS</b> , senhas protegidas por <b>Argon2id</b> , criptografia de campos clínicos sensíveis em repouso, <b>APP_KEY</b> mantida fora do código-fonte e                              |

|                        |                                                                                                                                                                   |         |                                                                                                                                                                                                                                                                                                                          |
|------------------------|-------------------------------------------------------------------------------------------------------------------------------------------------------------------|---------|--------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
|                        |                                                                                                                                                                   |         | controle de acesso por perfil.                                                                                                                                                                                                                                                                                           |
| Denial of Service      | Sobrecarga da aplicação por grande volume de tentativas de login, validação de 2FA ou solicitações de recuperação de senha.                                       | Alto    | <b>Rate limiting de 5 tentativas por minuto</b> para login e 2FA e <b>throttle de 60 segundos</b> no fluxo de recuperação de senha, reduzindo requisições abusivas sobre operações de autenticação.                                                                                                                      |
| Elevation of Privilege | Manipulação de rotas ou identificadores para acessar crianças, planos terapêuticos, registros clínicos ou funcionalidades pertencentes a outro usuário ou perfil. | Crítico | <b>Autorização no backend</b> , controle de acesso baseado em perfis e vínculo com os recursos.<br>Responsável Legal acessa somente crianças vinculadas;<br>Fonoaudiólogo acessa pacientes autorizados;<br>Coordenador possui acesso de supervisão;<br>e Administrador de TI não deve acessar conteúdo clínico sensível. |

## 29. Resumo Científico Estruturado (200 a 300 palavras)

**Objetivo:** Projetar e implementar um sistema web para fonoaudiologia que integre planejamento terapêutico, prescrição de exercícios e acompanhamento da evolução do paciente, com medidas de segurança e autenticação conformes à LGPD. **Métodos:** Estudo de produção tecnológica, desenvolvido ao longo de 2026, estruturado em quatro etapas: levantamento de requisitos e modelagem de processos, contemplando os fluxos da fonoaudiologia infantil e os requisitos de segurança e proteção de dados previstos na Lei nº 13.709/2018 (LGPD); arquitetura de software e modelagem de dados, com definição da arquitetura MVC, modelagem relacional do banco de dados e desenvolvimento de interface responsiva; implementação dos módulos e mecanismos de segurança, utilizando Laravel com PHP no back-end, Bootstrap no front-end e MySQL, com hash de senhas Argon2id, autenticação em dois fatores, controle de acesso por perfil e trilha de auditoria; e testes e validação, por meio de testes funcionais e de segurança, verificação dos controles de acesso e registro de evidências de funcionamento. **Resultados:** Obteve-se uma versão inicial da plataforma com quatro módulos: cadastro de crianças e plano terapêutico, biblioteca de exercícios de estimulação da fala com suporte a vídeo, diário de evolução e painel de gestão clínica. Os mecanismos de segurança foram implementados e validados por testes funcionais e de controle de acesso. **Conclusão:** O sistema integra planejamento, prescrição de exercícios e acompanhamento da evolução em uma única plataforma, proporcionando histórico rastreável e salvaguardas para dados sensíveis de menores. Recomenda-se sua aplicação em serviços de fonoaudiologia infantil para avaliar a adesão familiar aos exercícios domiciliares.

### 30. Matriz de Rastreabilidade de Requisitos (RTM Geral)

| Itens do Checklist | Escopo Avaliativo do Projeto                                    | Requisito Funcional (RF) | Requisito Não Funcional (RNF) | Artefato de Evidência Técnica                                      |
|--------------------|-----------------------------------------------------------------|--------------------------|-------------------------------|--------------------------------------------------------------------|
| 1.1 a 1.4          | Hash de senhas, parâmetros de custo, salt e persistência segura | RF-01, RF-02             | RNF-01                        | Benchmark Argon2id, config/hashing.php e evidências de credenciais |

| <b>Itens do Checklist</b> | <b>Escopo Avaliativo do Projeto</b>                               | <b>Requisito Funcional (RF)</b> | <b>Requisito Não Funcional (RNF)</b> | <b>Artefato de Evidência Técnica</b>                                  |
|---------------------------|-------------------------------------------------------------------|---------------------------------|--------------------------------------|-----------------------------------------------------------------------|
| <b>1.5 a 1.8</b>          | <b>Autenticação 2FA, validação pós-1º fator, fluxo e testes</b>   | <b>RF-03</b>                    | <b>RNF-14</b>                        | <b>UC-01, fluxo de autenticação e evidências do 2FA</b>               |
| <b>1.9 a 1.12</b>         | <b>Sessão, logout, rate limiting e justificativas técnicas</b>    | <b>RF-04, RF-05</b>             | <b>RNF-02, RNF-03</b>                | <b>Configuração de sessão, Rate Limiting e evidências funcionais</b>  |
| <b>2.1 a 2.7</b>          | <b>Recuperação de senha, token temporário, invalidação e logs</b> | <b>RF-06, RF-07</b>             | <b>RNF-11, RNF-14</b>                | <b>Fluxo de recuperação, config/auth.php e logs de recuperação</b>    |
| <b>3.1 a 3.8</b>          | <b>HTTPS/TLS, criptografia em repouso e proteção da chave</b>     | <b>RF-01, RF-05, RF-16</b>      | <b>RNF-04, RNF-05, RNF-06</b>        | <b>EnsureHttps, AES-256-CBC, APP_KEY e evidências de criptografia</b> |
| <b>4.1 a 4.11</b>         | <b>LGPD, minimização, consentimento e direitos do titular</b>     | <b>RF-08 a RF-12, RF-18</b>     | <b>RNF-08, RNF-09</b>                | <b>Tabela RoPA, Matriz de Direitos do Titular e endpoints LGPD</b>    |
| <b>5.1 a 5.4</b>          | <b>Auditoria, logs de autenticação, falhas, 2FA e integridade</b> | <b>RF-13 a RF-15</b>            | <b>RNF-10, RNF-11</b>                | <b>logs_auditorias, cadeia SHA-256 e painel de auditoria</b>          |

### 31. Referências

GARCIA, Lara Rocha *et al.* **Lei Geral de Proteção de Dados (LGPD) Guia de Implantação**. São Paulo: Editora Edgard Blucher Ltda., 2020.

GUARNIERI, Camilla e ARNDT, Bruno Felipe e LOPES-HERRERA, Simone Aparecida. Levantamento dos Aplicativos mobile na área de Fonoaudiologia. 2014, Anais.. São Paulo: Sociedade Brasileira de Fonoaudiologia, 2014. . Acesso em: 27 set. 2026.

**Vista do Fonoaudiologia em saúde pública/coletiva: compreendendo prevenção e o paradigma da promoção da saúde.** Disponível em:

<<https://revistas.pucsp.br/index.php/dic/article/view/11631/8357>>. Acesso em: 27 set.. 2026.

GONÇALO, Wemerson *et al.* Abordagens regulatórias na proteção de dados em saúde: uma revisão integrativa de 2018 a 2023. **Physis: Revista de Saúde Coletiva**, v. 35, n. 1, 2025.

TEFFÉ, Chiara Spadaccini de; VIOLA, Mario. Tratamento de dados pessoais na LGPD: estudo sobre as bases legais. **civilistica.com**, v. 9, n. 1, p. 1–38, 9 maio 2020.